
ISO/IEC 27701:2025

Plain-Language Control and Audit Guide

What every requirement means, why it exists, how to audit it, what evidence to collect, how to document it, and how to report it.

Coverage

Clauses 4 through 10, the standalone PIMS management system.
Annex A, all 78 controls across the three groups.

Audience

Internal auditors, privacy officers, control owners, and anyone who has to explain a privacy requirement to somebody who does not work in privacy.

Before You Use This Document

This is a companion guide, not a copy of the standard.

ISO/IEC 27701:2025 is a copyrighted publication of ISO and IEC. Nothing in this document reproduces the text of the standard. Every requirement here is described in original wording, using the official clause and control numbering as reference points only. Your organization still needs a licensed copy of ISO/IEC 27701:2025, including its Annex B implementation guidance. Where this guide and the standard appear to differ, the standard governs.

This guide covers the 2025 edition only. If your certificate or your programme is still based on ISO/IEC 27701:2019, the structure will not match: that edition was an extension requiring ISO/IEC 27001 and used a different control set.

What this guide does

It takes each requirement in ISO/IEC 27701:2025 and answers six questions about it, in the same order every time:

1. **What the control asks for.** The requirement in ordinary language, with no assumed background.
2. **Why it exists.** The failure it is there to prevent. Auditors who understand intent write better findings than auditors who only know the wording.
3. **How to audit it.** Specific test steps, in the order you would actually perform them.
4. **Evidence to collect.** Named artifacts. Not “documentation” but the actual thing to request.
5. **How to document it.** What belongs in the workpaper so a reviewer can follow your reasoning without re-performing your work.
6. **Executive summary treatment.** Suggested language if the item fails or rates high risk, written for an audience that does not read control numbers.

On vocabulary

Technical terms are defined the first time they appear, shown like [this](#), and collected in the glossary. If you hit a term that is not defined, that is a defect in this document; note it and it will be fixed in the next revision.

Navigating this document

Each part opens with a quick-reference table. Every reference number and title in those tables is a live link to the full entry, so the tables work as a jump menu rather than just a contents list. Entries also appear in the PDF bookmark panel, and the index at the back links back into the text.

Link colour carries meaning, and the rule here answers the question every organization arriving from an existing ISMS asks first: what of my ISO/IEC 27001 work already counts?

Blue

The requirement has a direct ISO/IEC 27001:2022 counterpart. For the Annex A.3 controls that counterpart is named at the start of each entry, and the mapping is one to one for all twenty-nine. The Annex SL management clauses are shared as well. Existing ISMS evidence is reusable, subject to one check described below.

Orange, marked PRIV

The requirement is privacy-specific with no ISO/IEC 27001 counterpart. Nothing you already hold applies and the work is net-new. Fifty-one of the one hundred and five entries, comprising every controller and processor control plus the two clauses whose substance is privacy rather than generic management system machinery.

The check before you reuse anything. In the 2019 edition the PIMS scope was inherited from the ISMS scope, so the two matched by construction. In the 2025 edition the PIMS scope is set independently under Clause 4.3, and the two can diverge. Before accepting any ISO/IEC 27001 evidence against an A.3 control, compare the two scope statements. Evidence from a narrower ISMS proves nothing about processing that sits outside it, and this is now the most likely place for an integrated audit to go wrong.

The marker letters are printed as well as coloured, so the distinction survives greyscale printing and does not depend on colour vision. The classification is a judgment, not something the standard states; it is held in a single file in the source and can be re-scoped without touching any content.

One entry, one page

Every clause and control begins at the top of a fresh page and is complete before the next one starts. This wastes some paper and makes the document longer than it needs to be. It also means you can print a single control and hand it to the person who owns it, which is what these documents actually get used for.

Four things about this standard that catch people out

Role is determined per processing activity, not per organization. Most organizations are controllers for some processing and processors for other processing, frequently within the same product. An organization that describes itself as a processor and excludes the entire A.1 control set on that basis has almost certainly got it wrong, and the exclusion is the first thing to test at Clause 6.1.3.

Query, do not read. The highest-yield tests in this guide take minutes and produce findings that cannot be argued with. Query for data past its retention period. Search shared locations for accumulated exports. Look at what is actually in the test environment. Reviewing the retention schedule tells you what the organization intends; querying tells you what it does.

Privacy risk is not security risk. Security risk assessment measures harm to the organization. Privacy risk assessment must measure harm to the individual. An organization running privacy risk through a scale denominated in organizational impact will score every individual harm at or near zero and treat none of them, and that single structural fault explains a pattern of under-treatment across an entire programme.

The clock runs from awareness. Breach notification deadlines are measured in hours and start when the organization becomes aware, not when it confirms. Time spent deciding whether something is

a breach is time spent inside the notification window. When you test incident response, overlay the statutory clock on the timeline; that overlay is what turns an incident record into a compliance finding.

Three definitions you need before anything else

PII principal

The individual the data is about. They hold rights exercisable directly against the organization and enforceable by a supervisory authority on their behalf, whether or not they have any commercial relationship with it. They are the party the whole standard exists to protect and the one most often missing from the interested party register.

Nonconformity

A failure to meet a requirement. A *major* nonconformity means a requirement is absent, or a failure is widespread, or it puts the reliability of the whole system in doubt. A *minor* nonconformity is an isolated lapse in a system that otherwise works. Certification is normally blocked by a major and not by a minor.

Lawful basis

The legal ground that permits processing at all. Determined per purpose, before processing begins, and capable of being demonstrated. Processing without one is unlawful however well it is secured, which makes this the most consequential single determination in the standard.

How to read the executive summary sections

Every entry ends with suggested reporting language. It is deliberately written to avoid three habits that get security findings ignored: control numbers in the first sentence, adjectives about maturity, and recommendations that amount to “do it better.” Each one names a specific consequence and, where possible, attaches a number. Adapt the wording; keep the structure.

Contents

Before You Use This Document	ii
1 The Management System: Clauses 4 to 10	1
4.1 Understanding the organization and its context	3
4.2 Understanding the needs and expectations of interested parties	4
4.3 Determining the scope of the PIMS	5
4.4 Privacy information management system	6
5.1 Leadership and commitment	7
5.2 Policy	8
5.3 Roles, responsibilities and authorities	9
6.1.1 Actions to address risks and opportunities: general	10
6.1.2 Privacy risk assessment	11
6.1.3 Privacy risk treatment	12
6.2 Privacy objectives and planning to achieve them	13
6.3 Planning of changes	14
7.1 Resources	15
7.2 Competence	16
7.3 Awareness	17
7.4 Communication	18
7.5.1 Documented information: general	19
7.5.2 Creating and updating documented information	20
7.5.3 Control of documented information	21
8.1 Operational planning and control	22
8.2 Privacy risk assessment	23
8.3 Privacy risk treatment	24
9.1 Monitoring, measurement, analysis and evaluation	25
9.2 Internal audit	26
9.3 Management review	27
10.1 Continual improvement	28
10.2 Nonconformity and corrective action	29
2 Annex A.1: PII Controller Controls	30
A.1.2.2 Identify and document purpose	32
A.1.2.3 Identify lawful basis	33
A.1.2.4 Determine when and how consent is to be obtained	34
A.1.2.5 Obtain and record consent	35
A.1.2.6 Privacy impact assessment	36
A.1.2.7 Contracts with PII processors	37
A.1.2.8 Joint PII controller	38
A.1.2.9 Records related to processing PII	39

A.1.3.2	Determining and fulfilling obligations to PII principals	40
A.1.3.3	Determining information for PII principals	41
A.1.3.4	Providing information to PII principals	42
A.1.3.5	Providing mechanism to modify or withdraw consent	43
A.1.3.6	Providing mechanism to object to PII processing	44
A.1.3.7	Access, correction or erasure	45
A.1.3.8	PII controllers' obligations to inform third parties	46
A.1.3.9	Providing copy of PII processed	47
A.1.3.10	Handling requests	48
A.1.3.11	Automated decision making	49
A.1.4.2	Limit collection	50
A.1.4.3	Limit processing	51
A.1.4.4	Accuracy and quality	52
A.1.4.5	PII minimization objectives	53
A.1.4.6	PII de-identification and deletion at the end of processing	54
A.1.4.7	Temporary files	55
A.1.4.8	Retention	56
A.1.4.9	Disposal	57
A.1.4.10	PII transmission controls	58
A.1.5.2	Identify basis for PII transfer between jurisdictions	59
A.1.5.3	Countries and international organizations to which PII can be transferred	60
A.1.5.4	Records of transfer of PII	61
A.1.5.5	Records of PII disclosures to third parties	62
3	Annex A.2: PII Processor Controls	63
A.2.2.2	Customer agreement	65
A.2.2.3	Organization's purposes	66
A.2.2.4	Marketing and advertising use	67
A.2.2.5	Infringing instruction	68
A.2.2.6	Customer obligations	69
A.2.2.7	Records related to processing PII	70
A.2.3.2	Comply with obligations to PII principals	71
A.2.4.2	Temporary files	72
A.2.4.3	Return, transfer or disposal of PII	73
A.2.4.4	PII transmission controls	74
A.2.5.2	Basis for PII transfer between jurisdictions	75
A.2.5.3	Countries and international organizations to which PII can be transferred	76
A.2.5.4	Records of PII disclosures to third parties	77
A.2.5.5	Notification of PII disclosure requests	78
A.2.5.6	Legally binding PII disclosures	79
A.2.5.7	Disclosure of subcontractors used to process PII	80
A.2.5.8	Engagement of a subcontractor to process PII	81
A.2.5.9	Change of subcontractor to process PII	82
4	Annex A.3: Information Security Controls	83
A.3.3	Policies for information security	85
A.3.4	Information security roles and responsibilities	86
A.3.5	Classification of information	87
A.3.6	Labelling of information	88

A.3.7	Information transfer	89
A.3.8	Identity management	90
A.3.9	Access rights	91
A.3.10	Addressing information security within supplier agreements	92
A.3.11	Information security incident management planning and preparation	93
A.3.12	Response to information security incidents	94
A.3.13	Legal, statutory, regulatory and contractual requirements	95
A.3.14	Protection of records	96
A.3.15	Independent review of information security	97
A.3.16	Compliance with policies, rules and standards for information security	98
A.3.17	Information security awareness, education and training	99
A.3.18	Confidentiality or non-disclosure agreements	100
A.3.19	Clear desk and clear screen	101
A.3.20	Storage media	102
A.3.21	Secure disposal or re-use of equipment	103
A.3.22	User endpoint devices	104
A.3.23	Secure authentication	105
A.3.24	Information backup	106
A.3.25	Logging	107
A.3.26	Use of cryptography	108
A.3.27	Secure development life cycle	109
A.3.28	Application security requirements	110
A.3.29	Secure system architecture and engineering principles	111
A.3.30	Outsourced development	112
A.3.31	Test information	113
Glossary		114
Index of Terms and Concepts		117

CHAPTER 1

The Management System: Clauses 4 to 10

Twenty-seven requirements that build and run the privacy information management system itself. In the 2025 edition these stand alone: they no longer sit on top of an ISO/IEC 27001 management system, and a PIMS can be certified without an ISMS underneath it.

Structurally these clauses follow the same Annex SL pattern as ISO/IEC 27001, which means an organization running both can operate one management system serving two standards. That is a genuine efficiency and it is why most of this part is blue. Two clauses are not: 6.1.2, because privacy risk measures harm to individuals rather than to the organization, and 6.1.3, because the applicability of the controller and processor control sets depends on a role determination that has no security equivalent.

Two tests are worth running early. At Clause 4.1, check whether the organization identified the jurisdictions of the individuals whose data it holds, rather than its own operating locations; getting this wrong invalidates the entire obligations analysis downstream. At Clause 4.3, if the organization also holds ISO/IEC 27001 certification, compare the two scope statements. Since the PIMS scope is now set independently, divergence is possible for the first time and it is the most likely place for an integrated programme to have a hole in it.

Quick reference: Clauses 4 to 10

Navigation: every reference and title below links to its full entry. Links shown in **orange** with a **cyb** or **ai** marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are **blue**.

Ref	Title	Primary evidence
4.1	Understanding the organization and its context	Context analysis with version and revision history
4.2	Understanding the needs and expectations of interested parties	Interested party and requirements register
4.3	Determining the scope of the PIMS	Scope statement, approved, dated, versioned
4.4	Privacy information management system	PIMS manual or equivalent describing processes and interactions
5.1	Leadership and commitment	Management review minutes recording decisions and actions
5.2	Policy	Internal privacy policy with approver, date, and version
5.3	Roles, responsibilities and authorities	Roles and responsibilities matrix covering the data lifecycle
6.1.1	Actions to address risks and opportunities: general	Register covering PIMS-level risks and opportunities
6.1.2 PRIV	Privacy risk assessment	Documented privacy risk assessment methodology with acceptance criteria
6.1.3 PRIV	Privacy risk treatment	Statement of Applicability covering all 78 controls, approved and versioned

Ref	Title	Primary evidence
6.2	Privacy objectives and planning to achieve them	Documented objectives at corporate and functional levels
6.3	Planning of changes	Change plans dated before implementation
7.1	Resources	Resourcing or capacity analysis for the privacy function
7.2	Competence	Competence requirements per privacy-relevant role
7.3	Awareness	Awareness content covering the three required elements
7.4	Communication	Communication plan covering internal and external audiences
7.5.1	Documented information: general	Master document register for the PIMS
7.5.2	Creating and updating documented information	Sampled documents with visible metadata
7.5.3	Control of documented information	Access control lists for the PIMS repository
8.1	Operational planning and control	Operational procedures across the PII life-cycle with frequencies
8.2	Privacy risk assessment	Assessment schedule and actual performance records
8.3	Privacy risk treatment	Treatment plan with original and current target dates
9.1	Monitoring, measurement, analysis and evaluation	Measurement plan with metrics, methods, frequencies, owners
9.2	Internal audit	Internal audit programme covering the full cycle
9.3	Management review	Review schedule and actual meeting dates
10.1	Continual improvement	Improvement register with triggers and outcomes
10.2	Nonconformity and corrective action	Nonconformity and corrective action register covering all sources

4.1 Understanding the organization and its context

WHAT THE CONTROL ASKS FOR

Record what the organization does, the environment it operates in, and the internal and external factors affecting its ability to run a privacy information management system. For a **PIMS** the context must establish which privacy laws reach the organization, which is determined by where the individuals are rather than by where the organization sits.

WHY IT EXISTS

Privacy obligations are jurisdictional and they arrive from the location of the people whose data you hold. An organization that has recorded its own locations but not the locations of its data subjects has not established which laws apply to it, and every downstream determination inherits that error.

HOW TO AUDIT IT

1. Obtain the context record and confirm it exists as documented information rather than as shared understanding.
2. Verify it identifies the jurisdictions of the individuals whose PII is processed, not only the organization's own operating locations.
3. Check that the applicable privacy laws follow from that jurisdictional analysis rather than being a generic list.
4. Confirm the record addresses factors that bear specifically on privacy: regulatory change, supervisory authority activity, public expectation, and the organization's processing role.
5. Compare the record against the business as it currently operates, looking for new products, markets, or data flows since the last review.
6. Trace two context factors forward into the privacy risk assessment.

EVIDENCE TO COLLECT

- Context analysis with version and revision history
- Analysis of data subject jurisdictions
- Register of applicable privacy laws derived from that analysis
- Records of processing showing data flows and locations
- Review records following business change

HOW TO DOCUMENT IT

Record the jurisdictional analysis specifically: which data subject locations were identified and which laws were derived from them. Where a jurisdiction is missing, name it and state the obligation that consequently went unrecognized. Note the last review date against the most recent material business change.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization has not established which privacy laws apply to it, having assessed only its own operating locations rather than the locations of the individuals whose data it holds. Name a jurisdiction whose requirements are consequently unaddressed.

4.2 Understanding the needs and expectations of interested parties

WHAT THE CONTROL ASKS FOR

Identify the parties relevant to the PIMS and record what each requires. For privacy this population is led by **PII principals**, the individuals the data is about, who have enforceable rights against the organization whether or not they have any commercial relationship with it.

WHY IT EXISTS

PII principals hold rights that they can exercise directly and that supervisory authorities can enforce on their behalf. Unlike most interested parties they do not need the organization's cooperation to create an obligation. A register that records customers and regulators but not data subjects has omitted the party the entire standard exists to protect.

HOW TO AUDIT IT

1. Obtain the register and confirm it records specific requirements per party rather than a list of names.
2. Verify PII principals appear as a party distinct from customers, since in a processor relationship they are frequently the customer's data subjects rather than the organization's.
3. Check that supervisory authority expectations are recorded, including any published guidance the organization is subject to.
4. Sample customer contracts for privacy commitments, including processing restrictions, sub-processor terms, and assistance obligations.
5. Confirm requirements of PII principals were established rather than assumed, looking for research, complaint analysis, or consultation.
6. Trace two requirements through to a control or a risk entry.

EVIDENCE TO COLLECT

- Interested party and requirements register
- Identification of PII principal categories per processing activity
- Customer contracts containing privacy obligations
- Supervisory authority guidance applicable to the organization
- Complaint or enquiry analysis informing principal requirements

HOW TO DOCUMENT IT

State explicitly whether PII principals are represented and how their requirements were established. Record sampled contractual privacy obligations by clause reference, since these are enforceable commitments that frequently exceed what the organization's own controls deliver.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the individuals whose personal data the organization processes are not identified as interested parties, so their rights and expectations have never been established and could not have informed any control decision.

4.3 Determining the scope of the PIMS

WHAT THE CONTROL ASKS FOR

Define and document the boundaries of the privacy information management system: which processing activities, business units, locations, and systems are covered. The scope must account for context, interested party requirements, and relationships with third parties who process PII on the organization's behalf or on whose behalf it processes.

WHY IT EXISTS

In the 2025 edition the PIMS stands alone, so its scope is no longer inherited from an ISMS scope statement. That is a genuine change in audit approach: you can no longer assume the security scope and the privacy scope are the same, and where an organization holds both certifications the two statements must be compared rather than conflated.

HOW TO AUDIT IT

1. Read the scope statement and test whether it lets you determine, from the words alone, whether a given processing activity is in or out.
2. Where the organization also holds ISO/IEC 27001 certification, compare the two scope statements and identify processing inside the PIMS scope but outside the ISMS scope, and the reverse.
3. Test exclusions for dependency. Excluded processing that feeds an in-scope activity is not meaningfully excluded.
4. Verify third-party processing is addressed in both directions: processors acting for the organization, and processing the organization performs for its own customers.
5. Compare the documented scope to what customers and privacy notices are told.
6. Confirm the scope is available as documented information with version and approval.

EVIDENCE TO COLLECT

- Scope statement, approved, dated, versioned
- ISO/IEC 27001 scope statement where held, for comparison
- Records of processing showing activities in and out of scope
- Justification for exclusions with dependency analysis
- Processor and sub-processor arrangements
- Privacy notice and customer-facing coverage claims

HOW TO DOCUMENT IT

Where both certifications are held, present the scope comparison as a table of processing activity against PIMS scope and ISMS scope. Divergence between the two is a finding that only appears if you look for it deliberately, and it is common now that the PIMS scope is set independently.

EXECUTIVE SUMMARY TREATMENT

Suggested language: processing activities within the privacy management system's scope fall outside the information security management system's scope, so personal data covered by the privacy certification is not covered by the security controls the organization relies on to protect it.

4.4 Privacy information management system

WHAT THE CONTROL ASKS FOR

Establish, implement, maintain, and continually improve the PIMS, including the processes it needs and how they interact. This is the umbrella requirement the remaining clauses fill in, and in the 2025 edition it stands on its own rather than sitting on top of an ISMS.

WHY IT EXISTS

Privacy programmes are unusually prone to producing complete documentation that changes nothing. A record of processing, a set of privacy notices, and a completed impact assessment template can all exist while no processing was ever restricted, no collection reduced, and no retention shortened. This clause gives the auditor authority to report that.

HOW TO AUDIT IT

1. Ask the PIMS owner to walk you through how a new processing activity travels from proposal to approval to operation to review, naming who is accountable at each step.
2. Trace one processing activity end to end through that path, using dates.
3. Ask when the process last stopped, restricted, or materially changed a proposed processing activity. A privacy function that has never said no is worth examining.
4. Look for orphan processes: a record of processing nobody updates, assessments nobody reads, retention schedules nobody applies.
5. Compare document modification dates for evidence of continuous operation against pre-audit reconstruction.
6. Ask what the PIMS does differently than a year ago and request the supporting evidence.

EVIDENCE TO COLLECT

- PIMS manual or equivalent describing processes and interactions
- One traced processing activity with its full lifecycle record and dates
- Records of processing restricted, modified, or rejected through the process
- Document metadata showing edit and approval dates over time
- Evidence of improvements with triggers

HOW TO DOCUMENT IT

Present the end to end trace as a dated timeline. Record the answer to the question about when privacy governance last changed an outcome, close to verbatim, with the supporting evidence or a note of its absence.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the privacy management process has never restricted or prevented a proposed processing activity, which suggests it documents decisions rather than informing them. Support with the traced example and its dates.

5.1 Leadership and commitment

WHAT THE CONTROL ASKS FOR

Top management must lead the PIMS rather than approve it: ensuring the privacy policy and objectives fit the strategic direction, integrating PIMS requirements into business processes, providing resources, communicating the importance of effective privacy management, and supporting other managers in leading within their areas.

WHY IT EXISTS

Privacy requirements constrain revenue-generating activity in ways security requirements usually do not. Limiting collection, shortening retention, and refusing a secondary use all have commercial cost, which means the privacy function needs standing authority or it will lose every contested decision.

HOW TO AUDIT IT

1. Interview two or three members of top management separately. Ask what the privacy objectives are and how they relate to the business strategy.
2. Test integration into business processes: whether privacy appears in product design, procurement, and marketing approval, or is consulted after commitments are made.
3. Compare resources requested by the privacy function against resources approved across at least two cycles.
4. Review management review records for decisions rather than attendance.
5. Ask the PIMS owner where they lack authority to stop a processing activity, and check whether that was escalated and what followed.
6. Examine the reporting line for the privacy function, since one reporting into the function generating the data is structurally compromised.

EVIDENCE TO COLLECT

- Management review minutes recording decisions and actions
- Budget requests and approvals for the privacy function across cycles
- Product, procurement, and marketing procedures showing privacy gates
- Organizational chart showing privacy function reporting lines
- Leadership communications on privacy with dates
- Escalation records where authority gaps were raised

HOW TO DOCUMENT IT

Present resourcing as a requested-versus-approved table by cycle. Record the reporting line explicitly, since structural position is objectively verifiable and frequently explains findings elsewhere in the report.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the privacy function is consulted after processing decisions are made and reports into the leadership accountable for the revenue those decisions generate, so it has no practical ability to restrict a processing activity.

5.2 Policy

WHAT THE CONTROL ASKS FOR

Top management must establish a privacy policy appropriate to the organization, providing a framework for privacy objectives, committing to satisfy applicable requirements, and committing to continual improvement. It must be documented, communicated internally, and available to interested parties as appropriate.

WHY IT EXISTS

The internal privacy policy is distinct from the external privacy notice, and conflating the two is one of the most common failures in this clause. The notice tells data subjects what you do; the policy tells your staff what they must do. An organization with a polished notice and no internal policy has told the world its commitments without telling its own people how to meet them.

HOW TO AUDIT IT

1. Confirm an internal privacy policy exists and is distinct from the external privacy notice. Where only a notice exists, the clause is unmet.
2. Read the policy against each required element and record which are present, absent, or asserted without substance.
3. Confirm top management approval with an identifiable approver and date.
4. Test consistency against the external notice, since a policy permitting what the notice prohibits is a direct exposure.
5. Test communication by asking staff outside the privacy function what the policy requires of them.
6. Confirm a defined review cycle and evidence the last review occurred on schedule.

EVIDENCE TO COLLECT

- Internal privacy policy with approver, date, and version
- External privacy notice for comparison
- Top management approval evidence
- Communication and acknowledgement records across the workforce
- Review log with scheduled and actual dates

HOW TO DOCUMENT IT

Record explicitly whether an internal policy exists separately from the external notice. Where the two conflict, quote both with their references, since the finding is the contradiction and cannot be evidenced from one document alone.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization has a published privacy notice but no internal privacy policy, so the commitments made to data subjects have never been translated into requirements its staff are obliged to follow.

5.3 Roles, responsibilities and authorities

WHAT THE CONTROL ASKS FOR

Top management must assign and communicate responsibilities and authorities for PIMS-relevant roles, including ensuring the PIMS conforms to the standard and reporting on its performance. Where law requires a designated privacy role, that appointment sits here.

WHY IT EXISTS

Privacy responsibility crosses marketing, product, human resources, IT, and legal simultaneously, and each function reasonably assumes another owns it. Where a data protection officer or equivalent is legally required, the appointment also carries independence requirements that a purely internal assignment may not satisfy.

HOW TO AUDIT IT

1. Obtain the responsibility matrix and confirm it names holders for the two specifically required duties.
2. Where a designated privacy role is legally required, verify the appointment, its independence, and that it was notified where notification is required.
3. Test that role holders understand their responsibilities by asking them.
4. Check authority accompanies responsibility, particularly the authority to halt a processing activity.
5. Verify responsibilities cover the full data lifecycle, including retention and deletion, which are the duties most often unassigned.
6. Cross-check assignments against the current employee directory.

EVIDENCE TO COLLECT

- Roles and responsibilities matrix covering the data lifecycle
- Designated privacy role appointment and independence evidence
- Notification records to supervisory authorities where required
- Job descriptions or objectives containing privacy duties
- Current employee directory for reconciliation

HOW TO DOCUMENT IT

Record whether a legally required designated role exists, whether the holder is independent, and whether notification occurred, since each is separately verifiable and separately enforceable. Record lifecycle duties with confirmed owners.

EXECUTIVE SUMMARY TREATMENT

Suggested language: responsibility for applying retention and deletion requirements is unassigned, and consequently personal data is retained indefinitely across a stated number of systems. Where a designated role is required by law and absent, state that separately.

6.1.1 Actions to address risks and opportunities: general

WHAT THE CONTROL ASKS FOR

When planning the PIMS, consider the context and interested party requirements, then determine the risks and opportunities that must be addressed for the system to achieve its intended outcomes, to prevent undesired effects, and to achieve continual improvement. Plan the actions, integrate them, and define how effectiveness will be evaluated.

WHY IT EXISTS

These are risks to the management system itself rather than privacy risks to individuals. Loss of specialist privacy capability, a reorganization that removes the privacy function's reporting line, or regulatory change outpacing the organization's ability to respond can all disable the system that manages every other privacy risk.

HOW TO AUDIT IT

1. Confirm risks to the PIMS itself are recorded distinctly from privacy risks to individuals.
2. Verify inputs traceable from the context analysis and the interested party register.
3. Check opportunities are addressed and not only risks.
4. For a sample, confirm a planned action exists, is integrated into a PIMS process, and has a defined effectiveness measure.
5. Test effectiveness evaluation on an action completed at least six months ago.

EVIDENCE TO COLLECT

- Register covering PIMS-level risks and opportunities
- Traceability from context and interested party inputs
- Action plans with owners, dates, and integration points
- Effectiveness evaluation records

HOW TO DOCUMENT IT

State clearly whether PIMS-level risk is addressed separately from privacy risk to individuals, since conflating the two is the characteristic failure. Record traced inputs by name and the effectiveness conclusion for the sampled action.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization assesses privacy risks to individuals but not risks to the programme managing them, leaving predictable disruptions such as loss of specialist capability unplanned for.

6.1.2 Privacy risk assessment

WHAT THE CONTROL ASKS FOR

Define and apply a repeatable privacy risk assessment process, establishing criteria for risk acceptance and for performing assessments, producing consistent and comparable results, identifying privacy risks, analysing consequence and likelihood, and determining and prioritizing risk levels.

WHY IT EXISTS

Privacy risk differs from security risk in whose loss is measured. A security risk assessment measures harm to the organization; a privacy risk assessment must measure harm to the individual. An organization that runs privacy risk through a scale denominated in organizational impact will score every individual harm at or near zero and will treat none of them.

HOW TO AUDIT IT

1. Obtain the methodology and confirm it defines both acceptance criteria and criteria for performing assessments.
2. Test repeatability by independently applying the method to one recorded risk and comparing scores.
3. Examine the consequence scale specifically. Confirm it can express harm to individuals, including distress, discrimination, and loss of control, rather than only financial or reputational harm to the organization.
4. Confirm risk owners are named individuals with authority.
5. Check coverage against the records of processing and identify activities with no risk entry.
6. Verify the relationship between this clause and privacy impact assessment is understood, since the two are distinct and are frequently merged.

EVIDENCE TO COLLECT

- Documented privacy risk assessment methodology with acceptance criteria
- Privacy risk register with owners, analysis, and levels
- Consequence and likelihood scales
- Records of processing for coverage comparison
- Assessment session records with dates

HOW TO DOCUMENT IT

Quote the consequence scale and state whether it can represent harm to an individual. This single test determines whether the register is capable of representing privacy risk at all, and it explains under-treatment across the whole programme with one structural cause.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization's risk scale measures consequence only as harm to itself, so harms to individuals score at or near zero and are never prioritized for treatment. This explains a pattern of under-treatment rather than reporting its symptoms individually.

6.1.3 Privacy risk treatment

WHAT THE CONTROL ASKS FOR

Define and apply a process to select treatment options, determine the controls needed, compare those controls against the Annex A reference set, produce a **Statement of Applicability**, formulate a treatment plan, and obtain risk owner approval of the plan and the residual risk. Applicability of A.1 and A.2 depends on the organization's role as controller, processor, or both.

WHY IT EXISTS

This clause connects risk to action and produces the SoA. The role-dependent applicability of A.1 and A.2 is distinctive: an organization acting as both controller and processor must apply both sets, and organizations frequently exclude one on the basis of a self-description that their actual activity contradicts.

HOW TO AUDIT IT

1. Obtain the SoA and confirm it covers all 78 Annex A controls with a decision and substantive justification for each.
2. Test the role determination underlying any exclusion of A.1 or A.2. An organization excluding the controller set while determining its own processing purposes is a controller for that processing.
3. Check that role is determined per processing activity rather than as a single organizational label, since most organizations are controllers for some activities and processors for others.
4. Verify the A.3 security controls were assessed rather than assumed satisfied by an existing ISMS, and where an ISMS is relied on, confirm its scope covers the PIMS scope.
5. Check the treatment plan for owners, dates, and resources, aging overdue items against original dates.
6. Verify documented risk owner approval of the plan and residual risk.

EVIDENCE TO COLLECT

- Statement of Applicability covering all 78 controls, approved and versioned
- Role determination per processing activity
- Privacy risk treatment plan with owners, dates, status
- Risk owner approval records
- ISO/IEC 27001 SoA and scope where relied on for A.3
- Aging report for overdue treatment items

HOW TO DOCUMENT IT

Present the role determination per processing activity against the SoA's applicability decisions. Where A.2 is excluded but the organization processes on a customer's instructions, record the specific activity that contradicts the exclusion. Note whether A.3 was assessed independently or assumed from an ISMS whose scope may not match.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization excluded the processor control set on the basis that it is a controller, while processing personal data on behalf of a stated number of customers under their instructions. The exclusion is unsupported and the associated controls are untreated.

6.2 Privacy objectives and planning to achieve them

WHAT THE CONTROL ASKS FOR

Establish privacy objectives at relevant functions and levels, consistent with the policy, measurable where practicable, taking account of applicable requirements and risk assessment results, monitored, communicated, and updated. For each, plan the actions, resources, responsibility, deadline, and evaluation method.

WHY IT EXISTS

Objectives are what prevent a privacy programme from consisting entirely of statements about respecting privacy. The measurability requirement matters here more than in most standards because privacy objectives are unusually easy to phrase in a way that cannot fail.

HOW TO AUDIT IT

1. Confirm objectives exist below the corporate level and are held by the functions that collect and use personal data.
2. Test measurability by asking what number demonstrates success and where it comes from.
3. Verify linkage to privacy risk assessment results and to applicable legal requirements.
4. Confirm all five planning elements per objective: actions, resources, responsibility, deadline, evaluation method.
5. Compare the most recent measurement date to the stated monitoring frequency.
6. Test communication by asking staff in the relevant function what their team's privacy objective is.

EVIDENCE TO COLLECT

- Documented objectives at corporate and functional levels
- Objective plans covering all five required elements
- Most recent measurement results with dates
- Evidence of linkage to risk assessment outputs
- Communication records per level

HOW TO DOCUMENT IT

Use one table with a row per objective and a column per required element, marked present or absent. Quote objectives that are not measurable rather than describing them.

EXECUTIVE SUMMARY TREATMENT

Suggested language: privacy objectives are expressed as commitments to respect privacy rather than as measurable outcomes, so there is no basis for stating whether the privacy programme is succeeding. Quote one or two.

6.3 Planning of changes

WHAT THE CONTROL ASKS FOR

When the organization determines that changes to the PIMS are needed, those changes must be carried out in a planned manner. This concerns changes to the management system itself: scope, methodology, governance structure, or role determination.

WHY IT EXISTS

Management systems degrade fastest during change. A scope expansion made without revisiting the role determination, or a restructure that removes the privacy function's independence, can invalidate large parts of the system silently.

HOW TO AUDIT IT

1. Identify PIMS changes since the last audit: scope, methodology, governance, tooling, role determination.
2. Request the plan produced before each change; documentation created afterwards is a finding.
3. Assess whether the plan considered downstream effects on the risk assessment, the SoA, records of processing, and privacy notices.
4. Check communication to affected parties and currency of dependent documents.
5. Distinguish this clause from Clause 8, which covers operational change.

EVIDENCE TO COLLECT

- Change plans dated before implementation
- Impact assessments covering dependent processes and documents
- Approval records for significant PIMS changes
- Updated downstream documents with revision dates

HOW TO DOCUMENT IT

List every PIMS change in the period with its date and whether a plan predated it. Where downstream documents were not updated, name them and give the gap in days.

EXECUTIVE SUMMARY TREATMENT

Usually minor unless degradation followed. Suggested language: a change to the PIMS scope was implemented without reassessing the organization's processing role, and controls applicable to the newly in-scope processing were consequently never applied.

7.1 Resources

WHAT THE CONTROL ASKS FOR

Determine and provide the resources needed to establish, implement, maintain, and continually improve the PIMS: people, budget, tooling, time, and access to specialist expertise including legal.

WHY IT EXISTS

Privacy work requires legal interpretation as much as technical implementation, and most organizations resource one without the other. A privacy function with no access to qualified legal advice will make lawful basis determinations it is not equipped to make, and those determinations propagate into every processing activity.

HOW TO AUDIT IT

1. Establish what the organization determined it needs, looking for a documented analysis rather than accumulated headcount.
2. Compare determined need against actual provision across at least two cycles.
3. Assess skill mix rather than count, specifically whether legal, technical, and operational capability are all present.
4. Correlate shortfalls with other findings and link them explicitly.
5. Check access to external legal expertise where internal capability is absent.
6. Ask the PIMS owner what is currently not being done and compare to your own findings.

EVIDENCE TO COLLECT

- Resourcing or capacity analysis for the privacy function
- Budget requests and approvals across cycles
- Current headcount against approved and against assessed need
- Skills profile of the function
- Contracts for external legal or specialist support
- Backlog data, particularly for data subject requests

HOW TO DOCUMENT IT

Present requested versus approved by cycle, and cross-reference downstream findings by number. Record whether qualified legal input is available, since its absence explains lawful basis and transfer findings elsewhere.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the privacy function has no access to qualified legal expertise and is staffed below the level the organization itself assessed as necessary, which is the direct cause of a stated number of other findings in this report.

7.2 Competence

WHAT THE CONTROL ASKS FOR

Determine the competence needed by people whose work affects privacy performance, ensure they are competent on the basis of education, training, or experience, act where they are not, and retain documented evidence.

WHY IT EXISTS

Privacy determinations require judgment that cannot be inferred from a job title. Deciding whether a lawful basis applies, whether a transfer mechanism is valid, or whether de-identification is sufficient are all technical determinations that a competent-seeming person can get wrong in ways nobody notices until a regulator asks.

HOW TO AUDIT IT

1. Obtain competence requirements per privacy-relevant role.
2. Sample individuals and compare held evidence against the requirement.
3. Check that competence is verified rather than assumed; attendance records prove attendance.
4. Include the people making lawful basis and transfer determinations, since these are the highest-consequence judgments in the system.
5. Include contractors and third parties performing privacy-relevant work.
6. Check action taken where gaps were found and verify closure.

EVIDENCE TO COLLECT

- Competence requirements per privacy-relevant role
- Individual competence records: qualifications, certifications, assessments
- Competence evidence for those making legal determinations
- Contractor and third-party competence evidence
- Gap remediation records

HOW TO DOCUMENT IT

Build a sample table of person, role, required competence, evidence held, and conclusion. Record separately whether those making lawful basis determinations have verified competence to do so, since that is where the consequence is greatest.

EXECUTIVE SUMMARY TREATMENT

Suggested language: lawful basis determinations, which establish whether the organization's processing is legal at all, are made by people whose competence to make them has never been verified.

7.3 Awareness

WHAT THE CONTROL ASKS FOR

People doing work under the organization's control must be aware of the privacy policy, their contribution to the effectiveness of the PIMS, and the implications of not conforming. The population includes contractors and temporary staff.

WHY IT EXISTS

Most personal data is collected and handled by people whose primary job is something else. Privacy failures overwhelmingly originate in ordinary work: an over-broad export, a mailing list reused, a form collecting more than it needs. Awareness is the only control that reaches that population.

HOW TO AUDIT IT

1. Confirm content covers all three required elements, since programmes commonly cover data subject requests while never mentioning consequences of noncompliance.
2. Verify the population includes contractors by reconciling completion to a complete listing.
3. Test effect by asking staff scenario questions rather than whether they completed training.
4. Check timing for new starters relative to their access to personal data.
5. Verify content is role-relevant for functions handling large volumes of personal data, such as marketing, human resources, and customer service.
6. Check whether staff know how to recognize and escalate a data subject request, since unrecognized requests are a common source of missed deadlines.

EVIDENCE TO COLLECT

- Awareness content covering the three required elements
- Completion records reconciled to a complete population
- New starter records with dates
- Role-specific content for high-volume functions
- Knowledge assessment results if used

HOW TO DOCUMENT IT

Record the population reconciliation and the scenario question responses. Note specifically whether staff can recognize a data subject request, since a request that is not recognized starts no clock and the deadline is missed before anyone knows it began.

EXECUTIVE SUMMARY TREATMENT

Suggested language: staff who receive requests from individuals cannot recognize them as data subject requests, so statutory response clocks begin without anyone in the organization being aware. Give the awareness coverage figure alongside.

7.4 Communication

WHAT THE CONTROL ASKS FOR

Determine the internal and external communications relevant to the PIMS: what, when, with whom, and how. This is a planning requirement covering both routine communication and the communication required when something goes wrong.

WHY IT EXISTS

Privacy communication carries statutory deadlines that are shorter than most organizations expect. Breach notification to a supervisory authority, and to affected individuals where required, operates on clocks measured in hours. Deciding the routes in advance is what makes the deadline achievable.

HOW TO AUDIT IT

1. Obtain the communication plan and confirm it addresses what, when, with whom, and how.
2. Check external communication covers supervisory authorities, customers, and PII principals.
3. Verify breach notification deadlines are recorded per jurisdiction, since they differ and being wrong about them is costly.
4. Check that the plan identifies who decides whether notification is required, and that the decision authority is available out of hours.
5. Test against a real event if one occurred, comparing actual communication to the plan and to the deadline.
6. Confirm contact routes to supervisory authorities are current and verified.

EVIDENCE TO COLLECT

- Communication plan covering internal and external audiences
- Breach notification procedures with per-jurisdiction deadlines
- Supervisory authority contact details with verification dates
- Records of actual communications during any incident
- Notification decision authority and out of hours arrangements

HOW TO DOCUMENT IT

Record notification deadlines per jurisdiction against what the plan states, since errors here are both common and directly penalizable. For any actual notification, document the timeline in hours against the deadline.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization's breach notification procedure states a deadline longer than the one that applies to it in a named jurisdiction, so following its own procedure would produce a late notification and a penalty independent of the breach.

7.5.1 Documented information: general

WHAT THE CONTROL ASKS FOR

The PIMS must include the documented information the standard requires plus whatever the organization determines necessary for effectiveness. **Documented information** covers both documents, which state what should happen, and records, which evidence what did happen.

WHY IT EXISTS

Privacy is a domain where the record is the compliance. Demonstrating a lawful basis, demonstrating consent, and demonstrating that a request was handled within the deadline are all accountability obligations discharged by documentation. Processing that was lawful but undocumented cannot be shown to have been lawful.

HOW TO AUDIT IT

1. Build a checklist of every explicitly required documented information item and verify each exists.
2. Ask how the organization determined what additional documentation is necessary and whether that is recorded.
3. Test the accountability dimension: pick a processing activity and ask the organization to demonstrate its lawful basis from records alone.
4. Check that documents match practice and, where they differ, determine which is wrong.
5. Confirm retention periods for privacy records are defined, noting that consent and request records may need to outlive the processing.

EVIDENCE TO COLLECT

- Master document register for the PIMS
- The specific documented information items the standard requires
- Records demonstrating lawful basis for sampled processing
- Retention schedule covering privacy records

HOW TO DOCUMENT IT

Include the required-items checklist with the location of each or a note that it is absent. Record the lawful basis demonstration test: the activity selected, the records offered, and whether they would satisfy a supervisory authority.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization cannot demonstrate the lawful basis for a stated number of its processing activities from records, which is itself a failure of the accountability obligation regardless of whether the processing was lawful.

7.5.2 Creating and updating documented information

WHAT THE CONTROL ASKS FOR

When creating or updating documented information, ensure appropriate identification and description such as title, date, author, and reference; appropriate format and media; and appropriate review and approval for suitability and adequacy.

WHY IT EXISTS

Version identification matters unusually here because privacy notices change and the organization must be able to establish which notice a given individual was shown at the time their data was collected. A notice without version history cannot support that.

HOW TO AUDIT IT

1. Sample PIMS documents and check for title, identifier, version, date, author, and approver.
2. Verify the approver had authority; self-approval by the author is a common finding.
3. Check privacy notice version history specifically, and whether the organization can establish which version applied at a given date.
4. Compare repository copies against copies circulating elsewhere for divergence.
5. Confirm review addressed suitability and adequacy by asking the approver what they questioned.

EVIDENCE TO COLLECT

- Sampled documents with visible metadata
- Approval records with approver identity and date
- Privacy notice version history with effective dates
- Delegation of authority defining approval rights

HOW TO DOCUMENT IT

Record whether the organization can produce the privacy notice in force on a specified past date. Inability to do so undermines every consent and transparency claim relating to data collected before the current version.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization cannot establish which privacy notice was in force when personal data was collected, so it cannot demonstrate what individuals were told at the time and cannot support the lawful basis it now relies on.

7.5.3 Control of documented information

WHAT THE CONTROL ASKS FOR

Documented information must be available and suitable for use where and when needed, and protected from loss of confidentiality, improper use, or loss of integrity. Address distribution, access, retrieval, use, storage, preservation, version control, retention, and disposition, including external documents.

WHY IT EXISTS

PIMS documentation concentrates exactly what an attacker or a claimant would want: records of processing describing where personal data lives, impact assessments describing known weaknesses, and request records containing the personal data of the individuals who complained.

HOW TO AUDIT IT

1. Test access controls on the PIMS repository and check whether sensitive items such as request records are more tightly controlled than general policies.
2. Note that data subject request records contain personal data and are themselves subject to the standard's requirements.
3. Test retrieval by asking someone to locate a specific document and timing it.
4. Verify version control prevents superseded documents circulating.
5. Confirm retention and disposition are applied to privacy records.
6. Check control of external documents including supervisory authority guidance, and confirm the versions relied on are current.

EVIDENCE TO COLLECT

- Access control lists for the PIMS repository
- Version control configuration and history
- Retention schedule and disposal evidence for privacy records
- Register of external documents with currency dates

HOW TO DOCUMENT IT

Record the access review as who has access against who needs it. Note specifically whether data subject request records are access-controlled proportionate to the personal data they contain, since this is routinely overlooked.

EXECUTIVE SUMMARY TREATMENT

Suggested language: data subject request records, which contain the personal data of the individuals who submitted them, are accessible to a far wider group than needs them. The irony is worth stating plainly to a management audience.

8.1 Operational planning and control

WHAT THE CONTROL ASKS FOR

Plan, implement, and control the processes needed to meet PIMS requirements and to carry out the actions determined in Clause 6, across the PII lifecycle. Keep documented information sufficient for confidence the processes ran as planned, control planned changes, review unintended changes, and control externally provided processes.

WHY IT EXISTS

This is where the plan becomes operation and where the Annex A controls are actually applied. The unintended change requirement matters for privacy because processing expands without anyone deciding it should: a field added to a form, a new recipient added to an export, a retention setting left at default.

HOW TO AUDIT IT

1. Confirm operational processes exist across the PII lifecycle and run at their stated frequencies.
2. Test that records provide confidence processes ran as planned.
3. Examine unintended change: identify processing that expanded during the period without a decision, using system change records or data field comparisons.
4. Verify externally provided processing is controlled, with a mechanism that is exercised rather than merely contracted.
5. Look for processing activities operating outside the defined processes, using system inventories or expense records rather than the records of processing.
6. Confirm changes to processing triggered updates to records of processing and privacy notices.

EVIDENCE TO COLLECT

- Operational procedures across the PII lifecycle with frequencies
- Records evidencing execution
- Change records for systems processing personal data
- Contracts and oversight evidence for externally provided processing
- Records of processing with revision history

HOW TO DOCUMENT IT

Record any processing expansion you identified that was not accompanied by a decision, a records of processing update, or a notice update. That triple gap is the characteristic finding for this clause and is evidenced by comparing dates.

EXECUTIVE SUMMARY TREATMENT

Suggested language: personal data collection expanded during the period without any decision, assessment, or update to the organization's records of processing or its privacy notice, so individuals were not told about data being collected from them.

8.2 Privacy risk assessment

WHAT THE CONTROL ASKS FOR

Perform privacy risk assessments at planned intervals and when significant changes are proposed or occur, and retain documented information about the results. Clause 6.1.2 requires the process; this clause requires it to be run.

WHY IT EXISTS

Privacy risk changes as processing changes, and processing changes constantly. Scheduled assessment alone always lags. The trigger requirement is what keeps the assessment attached to what the organization is actually doing.

HOW TO AUDIT IT

1. Compare required frequency against actual performance dates.
2. Identify significant changes in the period independently, using change records, product launches, and vendor communications, then check whether each triggered an assessment.
3. Confirm the definition of significant change is documented.
4. Verify results are retained in enough detail to reconstruct the conclusion.
5. Compare successive assessments for genuine reassessment rather than a copied register.
6. Check that new processing activities and new recipients are treated as triggers.

EVIDENCE TO COLLECT

- Assessment schedule and actual performance records
- Definition of significant change
- Independently compiled list of significant changes
- Change-triggered assessment records
- Successive register versions

HOW TO DOCUMENT IT

Present significant changes you identified against whether an assessment followed each. Compiling the list independently is what gives this test its value; record your sources.

EXECUTIVE SUMMARY TREATMENT

Suggested language: new processing activities were introduced during the period without any privacy risk assessment, so the risk position on record describes processing the organization no longer performs.

8.3 Privacy risk treatment

WHAT THE CONTROL ASKS FOR

Implement the privacy risk treatment plan and retain documented information about the results. The plan agreed under 6.1.3 must be executed with records demonstrating it.

WHY IT EXISTS

The gap between agreed and completed remediation is where residual privacy risk lives. Privacy remediation is particularly prone to slippage because it frequently requires engineering capacity that is committed elsewhere, and because deferring it has no immediate visible consequence.

HOW TO AUDIT IT

1. Sample plan items and verify claimed completion against independent evidence rather than status fields.
2. Age open items against original committed dates and record how many times each date moved.
3. For completed items, confirm the treatment reduced the risk and the register was updated.
4. Identify items closed by late risk acceptance and confirm risk owner approval.
5. Check whether non-completion concentrates in items requiring engineering capacity.

EVIDENCE TO COLLECT

- Treatment plan with original and current target dates
- Independent completion evidence for sampled items
- Updated risk register showing revised residual risk
- Late risk acceptance approvals

HOW TO DOCUMENT IT

Produce an aging table of item, original due date, current due date, revision count, and days overdue against the original. The revision count reveals systemic slippage that a status field conceals.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of agreed privacy remediations are past their original committed dates, the oldest by a stated period, meaning risks to individuals that the organization decided to reduce remain live.

9.1 Monitoring, measurement, analysis and evaluation

WHAT THE CONTROL ASKS FOR

Determine what needs monitoring and measuring, the methods, when performed and by whom, and when results are analysed and by whom. Methods must produce valid results. Retain documented information and evaluate both privacy performance and PIMS effectiveness.

WHY IT EXISTS

Privacy performance is measurable in ways many organizations never attempt: request response times against deadlines, retention compliance, collection against stated purpose, consent withdrawal honoured. Without measurement the organization is asserting compliance rather than demonstrating it.

HOW TO AUDIT IT

1. Obtain the measurement plan and confirm it specifies what, how, when, and by whom for both performance and effectiveness.
2. Check that the metrics measure outcomes rather than activity. Counting requests received is activity; response time against deadline is outcome.
3. Verify retention compliance is measured, since it is the obligation most easily verified and most rarely checked.
4. Confirm measurement occurs at the stated frequency by comparing planned to actual dates.
5. Trace a measurement result to a decision.
6. Recalculate one metric independently and compare to the reported figure.

EVIDENCE TO COLLECT

- Measurement plan with metrics, methods, frequencies, owners
- Measurement results across multiple periods
- Data subject request response time data against deadlines
- Retention compliance measurement
- Analysis records with conclusions

HOW TO DOCUMENT IT

Record your independent recalculation against the reported figure. Note whether retention compliance is measured at all, since its absence means over-retention accumulates invisibly and is usually discoverable in minutes by querying.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization does not measure whether it deletes personal data at the end of its retention periods, and independent querying found records exceeding their limits by a stated period. Measurement absence and the resulting exposure are best reported together.

9.2 Internal audit

WHAT THE CONTROL ASKS FOR

Conduct internal audits at planned intervals to determine whether the PIMS conforms to the organization's own requirements and to the standard and is effectively implemented. Maintain an audit programme covering frequency, methods, responsibilities, planning, and reporting; ensure auditor objectivity; report results to relevant management; retain documented information.

WHY IT EXISTS

Internal audit is the organization's own detection capability for management system failure. For privacy it faces a specific difficulty: auditing whether a lawful basis determination was correct requires legal competence that general internal auditors usually lack, so audits often verify that a determination exists rather than whether it is right.

HOW TO AUDIT IT

1. Obtain the programme and confirm it covers the whole PIMS across a defined cycle, including all 78 Annex A controls and the management system clauses.
2. Verify the programme is risk-based rather than a fixed rotation.
3. Test auditor independence per audit.
4. Assess auditor competence for privacy subject matter specifically, including whether they can evaluate a lawful basis or transfer determination.
5. Compare planned to completed audits and examine deferrals.
6. Review reports for depth; no findings across an entire PIMS usually indicates shallow work.

EVIDENCE TO COLLECT

- Internal audit programme covering the full cycle
- Individual audit plans with criteria and scope
- Auditor independence declarations and reporting lines
- Auditor competence records covering privacy subject matter
- Completed reports with findings and delivery evidence

HOW TO DOCUMENT IT

Produce a coverage map of every clause and Annex A group against the date last internally audited. Record privacy-specific auditor competence separately from general audit competence, since only the first determines whether legal determinations were genuinely tested.

EXECUTIVE SUMMARY TREATMENT

Suggested language: internal audits verify that lawful basis determinations exist but not whether they are correct, because the auditors have no competence to evaluate them, so the organization has no assurance that its processing is lawful.

9.3 Management review

WHAT THE CONTROL ASKS FOR

Top management must review the PIMS at planned intervals for continuing suitability, adequacy, and effectiveness, considering the required inputs including prior actions, changes in issues and interested party needs, performance information covering nonconformities and monitoring results, audit results, objective achievement, interested party feedback, risk assessment and treatment status, and improvement opportunities. Outputs must include decisions on improvement and any changes needed.

WHY IT EXISTS

This is the governance loop that closes the system and the point at which evidence reaches people with authority to act. For privacy it is also where decisions that carry commercial cost, such as reducing collection or shortening retention, can actually be taken.

HOW TO AUDIT IT

1. Confirm reviews occurred at the planned frequency by comparing planned to actual dates.
2. Check attendance; top management must attend.
3. Work through every required input against the pack and minutes. Interested party feedback, including complaints from individuals, is the most commonly absent.
4. Test outputs for decisions with owners and dates rather than observations.
5. Trace prior actions forward with status.
6. Confirm an explicit conclusion on suitability, adequacy, and effectiveness.

EVIDENCE TO COLLECT

- Review schedule and actual meeting dates
- Attendance records identifying roles
- Review packs or input documents
- Minutes recording decisions, owners, and dates
- Action tracker showing prior actions and closure

HOW TO DOCUMENT IT

Use a checklist table of every required input against present or absent with the page reference where present. Record separately whether complaints from individuals reached the review, since that is the input most directly representing the people the system protects.

EXECUTIVE SUMMARY TREATMENT

Suggested language: management reviews do not consider complaints received from individuals, so leadership approves the privacy programme without being shown the experiences of the people it exists to protect.

10.1 Continual improvement

WHAT THE CONTROL ASKS FOR

Continually improve the suitability, adequacy, and effectiveness of the PIMS. No method is prescribed. It is tested by looking for evidence the system is deliberately improving, driven by measurement, audit, review, incidents, and complaints.

WHY IT EXISTS

Privacy law and supervisory authority expectations move continuously. A system that stands still falls behind without anyone deciding to let it, and the regulatory position that was defensible two years ago may not be now.

HOW TO AUDIT IT

1. Ask for improvements made in the period and the trigger for each.
2. Confirm improvement is driven by the system's own outputs rather than external pressure alone.
3. Distinguish improvement from correction.
4. Assess whether improvements were evaluated for effect.
5. Check whether the system adapted to regulatory or guidance developments during the period.
6. Look at trend data across periods and challenge flat trends alongside claimed improvement.

EVIDENCE TO COLLECT

- Improvement register with triggers and outcomes
- Evidence linking improvements to audit, measurement, or complaint data
- Before and after measurement for sampled improvements
- Records of adaptation to regulatory change

HOW TO DOCUMENT IT

Record improvements in a table of improvement, trigger, date, and measured effect. Note specifically whether the system responded to regulatory developments in the period, naming them.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the privacy management system has not changed in response to named regulatory developments during the period, and the changes described as improvements were not evaluated for effect.

10.2 Nonconformity and corrective action

WHAT THE CONTROL ASKS FOR

When a **nonconformity** occurs, react to control and correct it and deal with the consequences. Then evaluate whether action is needed to eliminate the cause, reviewing the nonconformity, determining its causes, and checking whether similar ones exist or could occur. Implement action, review its effectiveness, and change the PIMS if necessary. Retain documented information.

WHY IT EXISTS

The distinction between correction and corrective action is the point. For privacy this matters particularly because the same cause, such as a data collection form template used across many products, will surface repeatedly and appear each time as a separate incident.

HOW TO AUDIT IT

1. Confirm nonconformities from all sources feed one process: audit, incidents, complaints, monitoring, and self-identification.
2. For a sample, verify both correction and cause analysis occurred, and assess whether the recorded cause is a cause or a symptom.
3. Check the similar-occurrence review, particularly across processing activities sharing systems, templates, or vendors.
4. Verify effectiveness review occurred far enough after implementation to be meaningful.
5. Analyse recurrence across periods.
6. Confirm complaints from individuals are treated as a nonconformity source, since they are the most direct evidence available.

EVIDENCE TO COLLECT

- Nonconformity and corrective action register covering all sources
- Root cause analysis records
- Similar-occurrence review results across processing activities
- Effectiveness review records with dates
- Complaint records and their treatment

HOW TO DOCUMENT IT

For each sampled item record the stated cause and your assessment of whether it is a cause or a symptom. Present recurrence as counts by type across periods. Record whether complaints feed the process, since organizations frequently handle them as customer service matters and never treat them as control failures.

EXECUTIVE SUMMARY TREATMENT

Suggested language: complaints from individuals are handled as customer service enquiries and never treated as evidence of control failure, so a stated number of complaints raising the same issue produced no corrective action.

Annex A.1: PII Controller Controls

Thirty-one controls applying where the organization determines the purposes and means of processing. They divide into four groups: conditions for collection and processing (A.1.2), obligations to individuals (A.1.3), privacy by design and by default (A.1.4), and sharing, transfer and disclosure (A.1.5).

Every control in this group is privacy-specific. None has an ISO/IEC 27001 counterpart, and an organization arriving here from a mature ISMS will find that almost nothing it already has applies. That is the honest scoping message for this part of the standard.

Three tests carry disproportionate weight. Query for data past its retention period (A.1.4.8), because over-retention is the most common privacy failure and the easiest to evidence in minutes. List every field collected at a sample of collection points against its stated purpose (A.1.4.2), because unnecessary fields can be deleted the same week. And trace one consent withdrawal through every downstream system (A.1.3.5), because withdrawal that does not propagate is the failure organizations are least aware of.

Note also that role is determined per processing activity, not per organization. Most organizations are controllers for some activities and processors for others, so excluding this whole group on the basis of a single self-description is almost always wrong.

Quick reference: A.1 Controller

Navigation: every reference and title below links to its full entry. Links shown in **orange** with a **CYB** or **AI** marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are **blue**.

Ref	Title	Primary evidence
A.1.2.2 PRIV	Identify and document purpose	Records of processing showing purposes per activity
A.1.2.3 PRIV	Identify lawful basis	Lawful basis determination per purpose with reasoning
A.1.2.4 PRIV	Determine when and how consent is to be obtained	Documented consent approach per purpose
A.1.2.5 PRIV	Obtain and record consent	Consent records for sampled individuals
A.1.2.6 PRIV	Privacy impact assessment	Assessment threshold criteria
A.1.2.7 PRIV	Contracts with PII processors	Processor register reconciled to accounts payable
A.1.2.8 PRIV	Joint PII controller	Relationship classification analysis per third party
A.1.2.9 PRIV	Records related to processing PII	Records of processing activities
A.1.3.2 PRIV	Determining and fulfilling obligations to PII principals	Documented determination of obligations per jurisdiction
A.1.3.3 PRIV	Determining information for PII principals	Determination of required information
A.1.3.4 PRIV	Providing information to PII principals	Privacy notices for each population
A.1.3.5 PRIV	Providing mechanism to modify or withdraw consent	Withdrawal mechanism and interaction evidence

Ref	Title	Primary evidence
A.1.3.6 PRIV	Providing mechanism to object to PII processing	Objection mechanisms per applicable right and channel
A.1.3.7 PRIV	Access, correction or erasure	Request log for the period with receipt and response dates
A.1.3.8 PRIV	PII controllers' obligations to inform third parties	Disclosure records at individual level
A.1.3.9 PRIV	Providing copy of PII processed	Portability request records with output samples
A.1.3.10 PRIV	Handling requests	Request handling procedure with deadlines per jurisdiction
A.1.3.11 PRIV	Automated decision making	Inventory of automated decision making and profiling
A.1.4.2 PRIV	Limit collection	Field-level inventory per collection point
A.1.4.3 PRIV	Limit processing	Data flow documentation showing all uses per dataset
A.1.4.4 PRIV	Accuracy and quality	Accuracy mechanisms per processing activity
A.1.4.5 PRIV	PII minimization objectives	Documented minimization objectives
A.1.4.6 PRIV	PII de-identification and deletion at the end of processing	Purpose expiry criteria per processing activity
A.1.4.7 PRIV	Temporary files	Inventory of temporary file locations
A.1.4.8 PRIV	Retention	Retention schedule with periods and legal basis per category
A.1.4.9 PRIV	Disposal	Disposal policies and procedures by medium
A.1.4.10 PRIV	PII transmission controls	Transmission path inventory carrying PII
A.1.5.2 PRIV	Identify basis for PII transfer between jurisdictions	Data flow and hosting location documentation
A.1.5.3 PRIV	Countries and international organizations to which PII can be transferred	Documented destination list
A.1.5.4 PRIV	Records of transfer of PII	Transfer records for the period
A.1.5.5 PRIV	Records of PII disclosures to third parties	Disclosure records for the period

A.1.2.2 Identify and document purpose

WHAT THE CONTROL ASKS FOR

Identify and document the specific purposes for which PII is processed. Each purpose must be recorded, and it must be specific enough that you could tell whether a given use falls inside it.

WHY IT EXISTS

Purpose is the anchor for nearly every other privacy obligation. Lawful basis is assessed against a purpose, minimization is measured against a purpose, and retention runs until a purpose is exhausted. A vague purpose such as improving our services makes all three unassessable, which is frequently why it is chosen.

HOW TO AUDIT IT

1. Obtain the record of purposes and assess specificity. Test each by asking whether you could identify a use that falls outside it.
2. Compare recorded purposes against actual processing for a sample of activities, examining what the systems actually do.
3. Check that purposes are recorded per processing activity rather than as an organization-wide list.
4. Verify purposes align with what individuals are told in the privacy notice.
5. Look for secondary uses operating under a primary purpose, particularly analytics, product development, and model training.
6. Confirm new purposes trigger a documented decision rather than being absorbed into existing ones.

EVIDENCE TO COLLECT

- Records of processing showing purposes per activity
- Privacy notice for comparison
- System documentation or data flows showing actual use
- Approval records for new purposes
- Analytics and secondary use documentation

HOW TO DOCUMENT IT

Record the specific purpose text alongside the actual processing you observed, per sampled activity. Where a purpose is too vague to constrain anything, quote it, since the wording is the evidence. List secondary uses found operating without their own purpose.

EXECUTIVE SUMMARY TREATMENT

Suggested language: personal data is processed for purposes that were never documented, including a named secondary use, so the organization cannot demonstrate that the processing is limited to what individuals were told.

A.1.2.3 Identify lawful basis

WHAT THE CONTROL ASKS FOR

Determine and document the lawful basis for each processing purpose, and be able to demonstrate it. The basis must be identified before processing begins, and the applicable bases are set by the law of the jurisdiction concerned.

WHY IT EXISTS

Processing without a lawful basis is unlawful regardless of how carefully it is secured. This is the most consequential single determination in the whole standard, and it is frequently made by people without the competence to make it, then never revisited.

HOW TO AUDIT IT

1. Obtain the lawful basis recorded per purpose and confirm it is specific rather than a general assertion of legitimacy.
2. Test the reasoning. Where legitimate interests or an equivalent balancing basis is relied on, verify the assessment exists and considers the individual's interests, not only the organization's.
3. Check that consent is not recorded as the basis where the individual has no genuine choice, such as in an employment context, since that is a common and defective determination.
4. Verify the basis was determined before processing began, by comparing dates.
5. Check who made the determination and whether they were competent to make it, linking to Clause 7.2.
6. Confirm the basis is reassessed when purposes change.

EVIDENCE TO COLLECT

- Lawful basis determination per purpose with reasoning
- Balancing assessments where a legitimate interests basis is relied on
- Determination dates against processing start dates
- Competence evidence for the determiner
- Privacy notice statements of lawful basis for comparison

HOW TO DOCUMENT IT

Record the basis, the reasoning, and your assessment of whether the reasoning supports the conclusion. Where a balancing assessment is required and absent, that is a discrete finding independent of whether the basis is ultimately correct.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization relies on a legitimate interests basis for a stated number of processing activities without having performed the balancing assessment that basis requires, so the basis cannot be demonstrated and the processing may be unlawful.

A.1.2.4 Determine when and how consent is to be obtained

WHAT THE CONTROL ASKS FOR

Where consent is the lawful basis, determine and document when it must be obtained and how. This includes the point in the interaction at which it is sought, the information presented, and the mechanism used.

WHY IT EXISTS

Consent is the most demanding lawful basis and the most frequently defective. It must be freely given, specific, informed, and unambiguous, and consent obtained through a pre-ticked box, a bundled acceptance, or an unavoidable interface fails all four. Determining the mechanism in advance is what prevents each product team inventing its own.

HOW TO AUDIT IT

1. Identify where consent is relied on and obtain the documented approach for each.
2. Examine the actual consent mechanism as an individual would encounter it, rather than reviewing its description.
3. Test whether consent is genuinely optional. Where declining prevents access to an unrelated service, the consent is bundled and defective.
4. Check granularity: separate purposes should be separately consentable rather than accepted together.
5. Verify the information presented at the point of consent is sufficient for the consent to be informed.
6. Check that refusing is as easy as accepting.

EVIDENCE TO COLLECT

- Documented consent approach per purpose
- Screenshots or recordings of the actual consent interface
- Consent text presented to individuals
- Design records showing granularity decisions
- Legal review of consent mechanisms

HOW TO DOCUMENT IT

Capture the actual interface rather than its description, since consent defects are almost always visible in the interaction and invisible in the documentation. Record whether declining is as easy as accepting, with the specific interaction steps for each.

EXECUTIVE SUMMARY TREATMENT

Suggested language: consent is obtained through a mechanism where accepting requires one action and declining requires several, and separate purposes cannot be consented to separately. Both defects mean the consent relied on is unlikely to be valid.

A.1.2.5 Obtain and record consent

WHAT THE CONTROL ASKS FOR

Obtain consent in accordance with the determined approach, and keep a record of it. The record must show that a particular individual consented, to what, when, and on the basis of what information.

WHY IT EXISTS

Consent is only useful if it can be demonstrated. An organization relying on consent that cannot produce the record has, in practice, no lawful basis. The record must also capture what the individual was shown, because consent is only valid relative to the information presented at the time.

HOW TO AUDIT IT

1. Sample individuals and request the consent record for each, assessing whether it shows who, what, when, and on what information.
2. Check whether the record captures the notice version in force at the time, linking to Clause 7.5.2.
3. Verify consent records are retained for as long as the processing continues and beyond where demonstration may be needed.
4. Test the consent record against the actual processing: confirm processing is limited to what was consented to.
5. Check that consent obtained before a change in purpose was refreshed rather than assumed to continue.
6. Verify records are retrievable within a reasonable time.

EVIDENCE TO COLLECT

- Consent records for sampled individuals
- Notice version linkage within consent records
- Retention configuration for consent records
- Processing configuration showing scope against consent
- Records of consent refresh following purpose change

HOW TO DOCUMENT IT

Record, for each sampled individual, exactly what the consent record contains and whether it would demonstrate valid consent to a supervisory authority. Where the notice version is not captured, note that the consent cannot be shown to have been informed.

EXECUTIVE SUMMARY TREATMENT

Suggested language: consent records do not capture what individuals were told at the time they consented, so the organization cannot demonstrate the consent was informed and cannot rely on it.

A.1.2.6 Privacy impact assessment

WHAT THE CONTROL ASKS FOR

Assess the need for, and where required conduct, a privacy impact assessment for processing that may result in significant risk to individuals. The assessment examines the processing, its necessity and proportionality, the risks to individuals, and the measures addressing them.

WHY IT EXISTS

Impact assessment looks outward at what processing does to people, which is a different question from what threatens the organization. It is also frequently a legal requirement rather than good practice, with the assessment itself being the evidence a regulator examines first.

HOW TO AUDIT IT

1. Confirm a process exists for determining whether an assessment is required, with criteria rather than case-by-case judgment.
2. Compare processing activities against those criteria and identify activities that should have been assessed and were not.
3. Sample completed assessments and evaluate whether they examine necessity and proportionality, not only risk and mitigation.
4. Check timing: compare assessment completion to processing start dates.
5. Verify assessments identify risks to individuals rather than to the organization.
6. Check what happened where significant residual risk was identified, including whether consultation with a supervisory authority was required and performed.
7. Confirm reassessment on material change.

EVIDENCE TO COLLECT

- Assessment threshold criteria
- Completed privacy impact assessments with dates
- Processing start dates for comparison
- Records of action taken following assessment findings
- Supervisory authority consultation records where applicable

HOW TO DOCUMENT IT

Present assessment date against processing start date per sampled activity, with the variance. Negative variances are the core finding. Record whether any assessment ever changed the processing, since an assessment process that has never altered a design is documenting rather than assessing.

EXECUTIVE SUMMARY TREATMENT

Suggested language: privacy impact assessments for a stated number of high-risk processing activities were completed after processing began, and no assessment has resulted in a change to any processing activity.

A.1.2.7 Contracts with PII processors

WHAT THE CONTROL ASKS FOR

Have a written contract with each processor acting on the organization's behalf, covering the required terms: the subject matter and duration of processing, its nature and purpose, the categories of data and individuals, and the processor's obligations including security, sub-processing, assistance, and return or deletion.

WHY IT EXISTS

The contract is the only mechanism compelling a processor to do anything, and specific terms are legally mandatory rather than good practice. Generic confidentiality language does not satisfy the requirement, and its absence is directly enforceable against the controller regardless of how the processor actually behaves.

HOW TO AUDIT IT

1. Identify all processors by reconciling against accounts payable, since procurement records miss those engaged directly by business units.
2. Sample contracts and check for each required term individually rather than assessing them overall.
3. Verify sub-processing terms, including whether authorization is required and how changes are notified.
4. Check assistance obligations covering data subject requests and breach notification, with timeframes.
5. Confirm return or deletion obligations at termination and whether they have been exercised for ended relationships.
6. Check that contracts predate the start of processing, comparing dates.

EVIDENCE TO COLLECT

- Processor register reconciled to accounts payable
- Executed contracts for sampled processors
- Sub-processor authorization and notification records
- Contract dates against processing start dates
- Return or deletion evidence for terminated relationships

HOW TO DOCUMENT IT

Use a table with a row per processor and a column per required term, marked present, absent, or inadequate. The pattern shows whether the gap is a template problem or a negotiation problem. Record the accounts payable reconciliation result separately.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of processors handling personal data on the organization's behalf have no compliant contract, and a stated number were identified only by comparing the processor register to actual payments. Both are directly enforceable against the organization.

A.1.2.8 Joint PII controller

WHAT THE CONTROL ASKS FOR

Where the organization determines purposes and means jointly with another party, identify that joint controllership and establish an arrangement setting out each party's respective responsibilities, particularly regarding individuals' rights and the provision of information.

WHY IT EXISTS

Joint controllership arises more often than organizations recognize, typically through marketing platforms, embedded analytics, and co-branded services. It is frequently mistaken for a processor relationship, which produces the wrong contract and leaves individuals unable to determine who is accountable to them.

HOW TO AUDIT IT

1. Identify relationships where purposes and means may be jointly determined, examining marketing platforms, analytics, advertising partners, and co-delivered services.
2. Test the organization's classification of each relationship against what actually happens rather than what the contract calls it.
3. Where joint controllership exists, verify an arrangement is in place allocating responsibilities.
4. Check that individuals are told the essence of the arrangement and can exercise rights against either party.
5. Confirm the arrangement addresses who responds to requests and who notifies breaches.

EVIDENCE TO COLLECT

- Relationship classification analysis per third party
- Joint controller arrangements where identified
- Contracts for relationships classified as processor for comparison
- Privacy notice statements about joint controllers

HOW TO DOCUMENT IT

Record the organization's classification against your own for each sampled relationship, with reasoning. Misclassification of a joint controller as a processor is common and produces a contract that does not meet either requirement, which is worth stating explicitly.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a named third party jointly determines the purposes of processing with the organization but is treated as a processor, so no joint controller arrangement exists and individuals have no clear route to exercise their rights.

A.1.2.9 Records related to processing PII

WHAT THE CONTROL ASKS FOR

Maintain records of the processing carried out as a controller, covering purposes, categories of data and individuals, recipients, transfers, retention periods, and security measures.

WHY IT EXISTS

The records of processing are the foundational accountability document and the first thing a supervisory authority requests. They are also the working inventory from which retention, minimization, and transfer obligations are managed. An inaccurate record makes every dependent obligation unmanageable.

HOW TO AUDIT IT

1. Obtain the records and test completeness against independent sources: system inventories, data flows, and expense records revealing processing not otherwise recorded.
2. Verify each required element is present per activity rather than in general.
3. Test accuracy by comparing a sampled entry against the actual system, examining what data is really held and who really receives it.
4. Check retention periods are stated as specific periods rather than as until no longer needed.
5. Confirm the records are maintained rather than produced once, comparing revision dates to processing changes.
6. Verify recipients include all third parties, including those receiving data through embedded technologies.

EVIDENCE TO COLLECT

- Records of processing activities
- System inventory and data flow documentation for reconciliation
- Sampled system extracts showing actual data held
- Third-party recipient listings including embedded technologies
- Revision history against processing change records

HOW TO DOCUMENT IT

Test one entry against the live system in detail and record every divergence: data fields held but not recorded, recipients not listed, retention not applied. That single deep test is worth more than a completeness review of the whole document.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the records of processing do not reflect the data the organization actually holds or the third parties that actually receive it, so the document a supervisory authority would examine first is inaccurate.

A.1.3.2 Determining and fulfilling obligations to PII principals

WHAT THE CONTROL ASKS FOR

Determine and document the obligations owed to individuals under applicable law and the organization's own commitments, and fulfil them. Obligations vary by jurisdiction and by lawful basis.

WHY IT EXISTS

Rights differ across jurisdictions and some depend on which lawful basis is relied on. An organization applying one uniform set of rights will over-deliver in some places and, more seriously, under-deliver in others. Determining the obligations is what makes fulfilment testable.

HOW TO AUDIT IT

1. Obtain the documented determination of obligations and verify it is derived from the jurisdictional analysis at Clause 4.1.
2. Check that obligations are mapped to lawful basis where the right depends on it, such as portability and objection.
3. Verify a process exists to fulfil each identified obligation.
4. Test fulfilment for a sample of obligations rather than accepting the process description.
5. Check whether the organization can identify which obligations apply to a given individual, which requires knowing that individual's jurisdiction.
6. Confirm the determination is reviewed as law changes.

EVIDENCE TO COLLECT

- Documented determination of obligations per jurisdiction
- Mapping of obligations to lawful basis
- Fulfilment processes per obligation
- Evidence of fulfilment for sampled obligations
- Review records following legal change

HOW TO DOCUMENT IT

Present obligations by jurisdiction against whether a fulfilment process exists and whether it was tested. Record whether the organization can determine an individual's jurisdiction, since without that it cannot know which rights apply.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization cannot determine which jurisdiction an individual falls under and therefore which rights they hold, so it applies a single set of rights that under-delivers in a stated number of the jurisdictions it operates in.

A.1.3.3 Determining information for PII principals

WHAT THE CONTROL ASKS FOR

Determine and document the information that must be provided to individuals about the processing of their PII, including purposes, lawful basis, recipients, retention, transfers, and their rights.

WHY IT EXISTS

Transparency is the obligation on which the individual's ability to exercise every other right depends. A person who does not know their data is held cannot request access to it. The determination step matters because the required content is prescribed and organizations routinely omit elements they find awkward, particularly recipients and retention.

HOW TO AUDIT IT

1. Obtain the determination of required information and compare it against what applicable law prescribes.
2. Check the awkward elements specifically: named or categorized recipients, actual retention periods, transfer destinations and safeguards, and the right to complain to a supervisory authority.
3. Verify the determination distinguishes information required when data is collected from the individual and when it is obtained from elsewhere.
4. Confirm the determination covers all processing activities, not only the customer-facing ones.
5. Check that employee and candidate processing is addressed, since it is commonly overlooked.

EVIDENCE TO COLLECT

- Determination of required information
- Applicable legal requirements for comparison
- Privacy notices for each population including employees
- Analysis distinguishing direct and indirect collection

HOW TO DOCUMENT IT

Compare required elements against those determined, item by item, and record omissions individually. Note whether employee and candidate processing has its own determination, since a single customer-focused notice does not discharge the obligation to staff.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization has not determined what it must tell individuals about retention periods or the recipients of their data, and consequently tells them neither. Both are prescribed elements and their absence is directly enforceable.

A.1.3.4 Providing information to PII principals

WHAT THE CONTROL ASKS FOR

Provide the determined information to individuals, in a concise, transparent, intelligible, and easily accessible form, using clear and plain language, and at the right time.

WHY IT EXISTS

Information that is technically provided but practically unreadable does not discharge the obligation. The requirement is about comprehension, not availability, which means a legally complete notice written in dense legal language can still fail. Timing matters equally: information provided after collection came too late to inform a decision.

HOW TO AUDIT IT

1. Obtain the privacy notices and assess readability against the audience, including any audience likely to include children or vulnerable people.
2. Check timing by examining the actual collection points and confirming the information is presented before or at collection.
3. Verify accessibility, including whether the notice can be reached without effort from the point of collection.
4. Compare the notice against the determination at A.1.3.3 and identify determined information that is not actually provided.
5. Check indirect collection specifically, where the individual has no interaction with the organization and must be told separately.
6. Verify notices exist for every population, including employees and candidates.

EVIDENCE TO COLLECT

- Privacy notices for each population
- Collection point evidence showing what is presented and when
- Readability assessment or evidence of plain language review
- Indirect collection notification records
- Notice version history with effective dates

HOW TO DOCUMENT IT

Examine actual collection points rather than the notice in isolation, and record what an individual would see and when. For indirect collection, record whether any notification occurs at all, since this is the most commonly unmet element.

EXECUTIVE SUMMARY TREATMENT

Suggested language: individuals whose data the organization obtains from third parties are never told that it holds their data, so they have no means of exercising any of their rights over it.

A.1.3.5 Providing mechanism to modify or withdraw consent

WHAT THE CONTROL ASKS FOR

Where consent is relied on, provide individuals with a mechanism to modify or withdraw it, and act on withdrawal. Withdrawal must be as easy as giving consent was.

WHY IT EXISTS

Consent that cannot be withdrawn is not consent. This is also where the practical failure usually sits: the mechanism exists but withdrawal does not propagate, so processing continues in systems downstream of the one where the preference was recorded.

HOW TO AUDIT IT

1. Verify a withdrawal mechanism exists and test it as an individual would use it.
2. Compare the effort of withdrawal against the effort of consent; disparity is a defect.
3. Test propagation. Following a withdrawal, verify processing actually stopped in every system, including analytics platforms, marketing tools, and any data already exported to third parties.
4. Check the timeframe between withdrawal and cessation.
5. Verify third parties who received the data on the basis of that consent were informed.
6. Confirm withdrawal is recorded so it can be demonstrated.

EVIDENCE TO COLLECT

- Withdrawal mechanism and interaction evidence
- System listing showing where consent state propagates
- Test results tracing a withdrawal through downstream systems
- Third-party notification records
- Withdrawal records with timestamps

HOW TO DOCUMENT IT

Trace one withdrawal end to end through every downstream system and record where processing continued. This propagation test is the substance of the control and is almost never performed by the organization itself.

EXECUTIVE SUMMARY TREATMENT

Suggested language: withdrawal of consent is recorded in the primary system but does not propagate to a stated number of downstream systems, so processing continues after individuals have withdrawn their permission for it.

A.1.3.6 Providing mechanism to object to PII processing

WHAT THE CONTROL ASKS FOR

Provide individuals with a mechanism to object to processing where they have that right, and act on objections received. Objection differs from consent withdrawal: it applies to processing carried out on bases other than consent.

WHY IT EXISTS

The right to object applies most commonly to direct marketing and to processing on a legitimate interests basis, and in the marketing case it is usually absolute. Organizations frequently provide an unsubscribe mechanism for email while continuing to process the same individual for marketing through other channels.

HOW TO AUDIT IT

1. Identify where a right to object applies and confirm a mechanism exists for each.
2. Test the marketing objection specifically across every channel, not only email, including post, telephone, and targeted advertising audiences.
3. Verify objections are acted on and that processing ceases rather than merely the channel being suppressed.
4. Check the organization's handling of objections to legitimate interests processing, and whether it can demonstrate compelling grounds where it continues.
5. Confirm objections are recorded and honoured persistently, including after a later data import that might reintroduce the individual.

EVIDENCE TO COLLECT

- Objection mechanisms per applicable right and channel
- Suppression list configuration and coverage across channels
- Records of objections received and actions taken
- Compelling grounds assessments where processing continued
- Evidence that suppression survives data imports

HOW TO DOCUMENT IT

Test whether an objection is honoured across all channels, not only the one it was submitted through. Record whether suppression survives a subsequent data import, since reintroduction after a list refresh is a common and repeated failure.

EXECUTIVE SUMMARY TREATMENT

Suggested language: individuals who object to marketing are suppressed for email only and continue to receive contact through other channels, and suppression is lost when new data is imported.

A.1.3.7 Access, correction or erasure

WHAT THE CONTROL ASKS FOR

Provide mechanisms for individuals to access, correct, or have erased the PII the organization holds about them, and act on those requests within the applicable timeframes.

WHY IT EXISTS

These are the rights individuals actually exercise, and the ones supervisory authorities receive complaints about. Access in particular is demanding because it requires the organization to find all data about one person across every system, which is only possible if it knows where personal data lives.

HOW TO AUDIT IT

1. Obtain the request log for the period and verify completeness, including requests received through channels other than the formal one.
2. Measure response times against the applicable statutory deadline and report the distribution rather than the average.
3. Test completeness of access responses by tracing one request against the systems that hold data about that individual.
4. Verify erasure actually erases, including from backups, archives, and non-production environments, or that a documented approach to backups exists.
5. Check identity verification is proportionate and does not itself obstruct the right.
6. Examine refused requests and whether the refusal ground was valid and communicated.

EVIDENCE TO COLLECT

- Request log for the period with receipt and response dates
- System listing showing where personal data about an individual may reside
- Response packages for sampled requests
- Erasure evidence including treatment of backups
- Identity verification procedures
- Refusal records with stated grounds

HOW TO DOCUMENT IT

Trace one access request against the full system inventory and record data that existed but was not disclosed. Report response times as a distribution against the deadline, since the average conceals the breaches. Record the backup position on erasure explicitly.

EXECUTIVE SUMMARY TREATMENT

Suggested language: access responses omitted personal data held in a stated number of systems, and a stated proportion of requests were answered after the statutory deadline, the longest by a stated number of days.

A.1.3.8 PII controllers' obligations to inform third parties

WHAT THE CONTROL ASKS FOR

Where PII has been disclosed to third parties, inform them of any correction, erasure, or restriction the organization applies, unless this proves impossible or involves disproportionate effort.

WHY IT EXISTS

A correction that stops at the organization's boundary leaves incorrect data circulating elsewhere, and an erasure that does not reach recipients leaves the individual's data live in systems they have never heard of. This obligation is what makes rights effective beyond the organization itself, and it is one of the least implemented requirements in the standard.

HOW TO AUDIT IT

1. Verify the organization knows which third parties received data about a given individual, which requires disclosure records at the individual level rather than the category level.
2. Check whether a process exists to notify recipients of corrections, erasures, and restrictions.
3. Sample rights requests actioned during the period and verify recipients were notified.
4. Where the organization claims disproportionate effort, assess whether that claim is supported.
5. Check that notification is recorded so it can be demonstrated.

EVIDENCE TO COLLECT

- Disclosure records at individual level
- Notification process for corrections and erasures
- Notification records for sampled rights requests
- Disproportionate effort assessments where claimed

HOW TO DOCUMENT IT

Test whether the organization can identify the recipients of a specific individual's data. Where disclosure is tracked only by category, record that the obligation cannot be met at all, since the prerequisite information does not exist.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization does not record which third parties received which individual's data, so when it erases or corrects data at an individual's request it cannot inform the recipients, and the incorrect or erased data remains live elsewhere.

A.1.3.9 Providing copy of PII processed

WHAT THE CONTROL ASKS FOR

Provide individuals with a copy of the PII processed about them, in a form that is usable, and where required in a structured, commonly used, machine-readable format allowing transmission to another controller.

WHY IT EXISTS

This goes beyond access: the individual is entitled to take the data with them. Portability is the right most often implemented in name only, with organizations providing a formatted report rather than data another provider could ingest.

HOW TO AUDIT IT

1. Identify where portability applies, noting it generally attaches only to data provided by the individual and processed by automated means on a consent or contract basis.
2. Examine the actual output format and assess whether another controller could ingest it.
3. Distinguish the portability output from the access response, since a single package frequently serves both and satisfies neither properly.
4. Test the scope of data included against what the individual provided.
5. Check whether direct transmission to another controller is offered where technically feasible.
6. Verify response times against the applicable deadline.

EVIDENCE TO COLLECT

- Portability request records with output samples
- Format specification for portability outputs
- Analysis of which processing attracts the portability right
- Direct transmission arrangements where offered

HOW TO DOCUMENT IT

Obtain an actual output and assess it as a receiving controller would. Record the format and whether it is genuinely machine-readable, since a PDF report labelled as a portability response is a common and readily evidenced failure.

EXECUTIVE SUMMARY TREATMENT

Suggested language: portability requests are answered with a formatted document rather than structured data, so individuals cannot transfer their data to another provider, which is the entire purpose of the right.

A.1.3.10 Handling requests

WHAT THE CONTROL ASKS FOR

Define and operate a process for handling requests from individuals, covering receipt, identity verification, assessment, response, and record keeping, within the applicable timeframes.

WHY IT EXISTS

The process is what makes rights deliverable at volume and within deadline. The most common failure is not refusal but silence: a request arrives through a channel nobody monitors, is not recognized as a request, and the clock expires before anyone knows it started.

HOW TO AUDIT IT

1. Obtain the process and confirm it covers all request types, all receipt channels, and the applicable deadlines per jurisdiction.
2. Test recognition by asking front-line staff how they would identify and escalate a request.
3. Verify the request log is complete by searching other channels, such as general enquiry inboxes and support tickets, for requests that never entered the process.
4. Measure receipt-to-response intervals against deadlines and report the distribution.
5. Check identity verification is proportionate and does not collect more data than needed.
6. Verify extensions, where used, were justified and communicated within the original deadline.

EVIDENCE TO COLLECT

- Request handling procedure with deadlines per jurisdiction
- Request log for the period
- Search results from other channels for unlogged requests
- Response records with dates
- Identity verification records
- Extension notifications

HOW TO DOCUMENT IT

Search channels outside the formal process for unrecognized requests and record what you found. This search is the highest-value test in the control, because unlogged requests do not appear in any metric the organization reports.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of requests from individuals were received through channels outside the request process and were never recognized or answered, so the statutory deadline expired without any response.

A.1.3.11 Automated decision making

WHAT THE CONTROL ASKS FOR

Where processing includes automated decision making, including profiling, that produces legal or similarly significant effects, identify it and implement the required measures: informing individuals, providing meaningful information about the logic, and enabling human intervention, expression of a point of view, and contest.

WHY IT EXISTS

Automated decisions affect individuals directly and are frequently invisible to them. Organizations often assume the requirement does not apply because a human is nominally in the loop, but a human who rubber-stamps an automated recommendation without the ability or information to disagree does not constitute meaningful intervention.

HOW TO AUDIT IT

1. Identify processing involving automated decisions or profiling with significant effects, examining recruitment, credit, pricing, fraud, and access decisions.
2. Test the claim of human involvement where made. Ask what information the reviewer sees, how often they disagree with the system, and whether they have authority to override.
3. Verify individuals are informed that automated decision making occurs.
4. Check whether meaningful information about the logic is provided, and assess whether it would let an individual understand the basis of a decision about them.
5. Verify the routes to intervention, expression of view, and contest exist and are usable.
6. Check whether any contest has ever succeeded, since a route that never changes an outcome is not a route.

EVIDENCE TO COLLECT

- Inventory of automated decision making and profiling
- Human review procedures with override authority
- Override and disagreement statistics
- Information provided to individuals about the logic
- Contest records with outcomes

HOW TO DOCUMENT IT

Record the override rate where human review is claimed. A rate at or near zero across a large volume indicates the review is nominal and the decision is effectively automated, which changes which obligations apply. Record whether any contest has succeeded.

EXECUTIVE SUMMARY TREATMENT

Suggested language: decisions the organization describes as human-reviewed are made automatically in practice, with reviewers overriding the system in a stated proportion of a stated number of cases, and individuals are not told that automated decision making is involved.

A.1.4.2 Limit collection

WHAT THE CONTROL ASKS FOR

Limit the collection of PII to what is adequate, relevant, and necessary for the identified purposes. Collection beyond that is not permitted regardless of whether it is secured or consented to.

WHY IT EXISTS

Data not collected cannot be breached, misused, or over-retained. Minimization at collection is the single most effective privacy control available and the one most often skipped, because collecting extra fields costs nothing at the point of design and the cost appears later.

HOW TO AUDIT IT

1. Sample collection points, including forms, applications, and integrations, and list every field collected.
2. Compare each field against the documented purpose and identify those serving no stated purpose.
3. Test optionality: check whether fields marked required are genuinely necessary.
4. Examine data collected through embedded technologies, which is frequently invisible to the organization that deployed them.
5. Check whether collection is reviewed when purposes change, and whether fields are ever removed.
6. Look at special category or sensitive data specifically, since its collection carries a higher threshold.

EVIDENCE TO COLLECT

- Field-level inventory per collection point
- Documented purposes for comparison
- Form configuration showing required and optional fields
- Embedded technology inventory and the data each collects
- Records of collection reduction following review

HOW TO DOCUMENT IT

List fields collected against stated purpose per sampled collection point and identify those with no purpose. This field-level comparison is concrete, quickly performed, and produces findings the organization can act on immediately by deleting fields.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of data fields are collected from individuals with no identified purpose, including a named sensitive category, increasing both regulatory exposure and the volume of data at risk in any breach.

A.1.4.3 Limit processing

WHAT THE CONTROL ASKS FOR

Limit processing of PII to what is adequate, relevant, and necessary for the identified purposes. This constrains use after collection, not just collection itself.

WHY IT EXISTS

Data collected for one purpose migrates into others: a customer record used for service becomes a marketing audience, then a training set, then an analytics input. Each step is small and none is decided. This control is what makes purpose limitation operational rather than aspirational.

HOW TO AUDIT IT

1. Sample datasets and identify every system and process that uses them.
2. Compare each use against the purpose the data was collected for, and identify uses beyond it.
3. Examine analytics, product development, and model training specifically, since these are the most common purpose extensions.
4. Check whether internal access to personal data is limited by need, or whether broad access is the default.
5. Verify that new uses require a decision, and check whether any use was refused during the period.
6. Check test and development environments, which frequently contain production personal data used for a purpose never assessed.

EVIDENCE TO COLLECT

- Data flow documentation showing all uses per dataset
- Purpose records for comparison
- Access listings for systems holding personal data
- Approval records for new uses
- Non-production environment data inventory

HOW TO DOCUMENT IT

Trace one dataset to every use and record each use against the purpose it was collected for. Record uses in non-production environments separately, since they are commonly overlooked entirely and carry the same obligations.

EXECUTIVE SUMMARY TREATMENT

Suggested language: personal data collected to deliver a service is also used for a named secondary purpose that individuals were not told about and that was never assessed, and production personal data is present in development environments accessible to a stated number of people.

A.1.4.4 Accuracy and quality

WHAT THE CONTROL ASKS FOR

Ensure PII is accurate, complete, and kept up to date as necessary for the purposes for which it is processed, and take reasonable steps to correct or delete inaccurate data.

WHY IT EXISTS

Inaccurate personal data produces wrong decisions about real people, and the consequence falls on the individual rather than the organization. Accuracy obligations scale with the significance of the decision: data driving a credit or employment decision demands more than data driving a newsletter.

HOW TO AUDIT IT

1. Identify the processing where accuracy most matters, based on the consequence of a wrong decision.
2. Check what mechanisms maintain accuracy: validation at entry, periodic refresh, individual self-service correction.
3. Verify correction requests are acted on and propagate to downstream systems and recipients.
4. Test accuracy directly where practical, by sampling records and checking internal consistency or comparing against a reliable source.
5. Check the treatment of data obtained from third parties, whose accuracy the organization has not verified.
6. Verify inaccurate data identified is corrected or deleted rather than left in place.

EVIDENCE TO COLLECT

- Accuracy mechanisms per processing activity
- Validation configuration at collection points
- Correction request records with propagation evidence
- Sample record accuracy testing results
- Third-party data source reliability assessments

HOW TO DOCUMENT IT

Record accuracy mechanisms against the consequence of inaccuracy per processing activity, since proportionality is the standard being applied. Where data is acquired from third parties, record whether its accuracy was ever assessed.

EXECUTIVE SUMMARY TREATMENT

Suggested language: personal data purchased from third parties and used to make decisions about individuals has never been assessed for accuracy, and corrections made at an individual's request do not propagate to the systems that use the data.

A.1.4.5 PII minimization objectives

WHAT THE CONTROL ASKS FOR

Define and document objectives for minimizing the PII processed, and design processing to meet them. Minimization here is a design objective applied continuously rather than a one-time assessment.

WHY IT EXISTS

Objectives turn minimization from a principle into something measurable. Without them, minimization is asserted at design review and never revisited, and data volumes grow monotonically because nothing ever triggers a reduction.

HOW TO AUDIT IT

1. Obtain the documented minimization objectives and assess whether they are specific enough to measure.
2. Verify objectives are applied at design, by examining recent designs for evidence of their influence.
3. Check whether minimization is ever applied retrospectively to existing processing, or only to new.
4. Look for evidence of actual reduction: fields removed, retention shortened, identifiers replaced.
5. Verify techniques such as pseudonymization and aggregation were considered where they would serve the purpose.
6. Check whether data volumes are measured at all, since minimization cannot be demonstrated without a baseline.

EVIDENCE TO COLLECT

- Documented minimization objectives
- Design records showing objective application
- Records of data reduction with dates
- Pseudonymization and aggregation analysis
- Data volume measurement across periods

HOW TO DOCUMENT IT

Record instances of actual reduction with dates. Their absence across a period is the finding, and it is more persuasive than any assessment of the objectives' wording. Note whether data volumes are measured, since without measurement no minimization claim is testable.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization has never reduced the personal data it holds for any processing activity, and does not measure data volumes, so its stated commitment to minimization cannot be demonstrated and has produced no observable effect.

A.1.4.6 PII de-identification and deletion at the end of processing

WHAT THE CONTROL ASKS FOR

Delete PII or render it de-identified as soon as the original purpose has expired, unless a legal requirement to retain applies. De-identification must be sufficient that individuals cannot reasonably be re-identified.

WHY IT EXISTS

Purpose expiry is the point at which continued holding becomes unlawful. De-identification is offered as an alternative to deletion, but weak de-identification that permits re-identification through combination with other data leaves the obligation unmet while creating the appearance of compliance.

HOW TO AUDIT IT

1. Identify processing where purposes have expired and check whether data was deleted or de-identified.
2. Test by querying for data whose purpose has ended and confirming whether it is still present and still identifiable.
3. Where de-identification is claimed, assess its strength, including whether re-identification is possible using other data the organization or a third party holds.
4. Check that de-identification is applied consistently across related fields, since partial application permits reconstruction.
5. Verify legal retention requirements relied on are real and specific rather than assumed.
6. Check that deletion reaches backups, archives, and non-production environments.

EVIDENCE TO COLLECT

- Purpose expiry criteria per processing activity
- Query evidence showing presence of expired data
- De-identification methods and re-identification risk assessment
- Legal retention requirements with citations
- Deletion evidence across backups and non-production

HOW TO DOCUMENT IT

Query for data past purpose expiry rather than reviewing the deletion procedure, and record the oldest record found in each category. Where de-identification is claimed, record the method and your assessment of re-identification risk, since claimed de-identification is often reversible.

EXECUTIVE SUMMARY TREATMENT

Suggested language: personal data whose purpose expired a stated period ago remains in production systems in identifiable form, and the de-identification applied elsewhere can be reversed using other data the organization holds.

A.1.4.7 Temporary files

WHAT THE CONTROL ASKS FOR

Ensure temporary files containing PII are deleted or disposed of within a documented period. Temporary files include caches, exports, intermediate processing outputs, logs, and working copies.

WHY IT EXISTS

Temporary files are the accidental data store. Exports created for a one-off analysis, caches that persist indefinitely, and intermediate files from failed processes all accumulate outside every retention control the organization operates, in locations nobody inventories.

HOW TO AUDIT IT

1. Identify where temporary files containing PII are created: export functions, reporting tools, integration staging areas, caches, and user workstations.
2. Check whether a documented deletion period exists for each and whether it is enforced technically.
3. Search actual locations for accumulated temporary files rather than reviewing the policy, examining shared drives, staging directories, and export folders.
4. Check the age of what you find against the documented period.
5. Verify user-created exports are covered, since these are the largest and least controlled category.
6. Confirm temporary files are covered by the same access controls as the source data.

EVIDENCE TO COLLECT

- Inventory of temporary file locations
- Documented deletion periods with enforcement configuration
- Directory listings from actual locations with file dates
- Export function configuration and logging
- Access controls on temporary file locations

HOW TO DOCUMENT IT

Search actual locations and record what you find with file ages and record counts. This is a quick test that reliably produces findings, and the volumes discovered are frequently larger than the organization expects.

EXECUTIVE SUMMARY TREATMENT

Suggested language: exports containing a stated number of individuals' personal data are accumulating in shared locations with no deletion, the oldest dating from a stated period, outside every retention control the organization operates.

A.1.4.8 Retention

WHAT THE CONTROL ASKS FOR

Retain PII only for as long as necessary for the identified purposes, with retention periods documented per category of data and applied in practice.

WHY IT EXISTS

Over-retention is the most common privacy failure and the easiest to evidence. It increases regulatory exposure and increases the volume of data at risk in any breach, for no business benefit whatsoever once the purpose has passed.

HOW TO AUDIT IT

1. Obtain the retention schedule and confirm it states specific periods per category with a stated basis.
2. Reject periods expressed as until no longer required, which are not periods.
3. Test application by querying systems for data past its stated period and recording the oldest record found.
4. Check whether retention is enforced technically or depends on manual deletion.
5. Verify retention applies to backups and archives, or that a documented approach exists.
6. Check legal retention requirements relied on for length, since these are frequently overstated to justify keeping data.

EVIDENCE TO COLLECT

- Retention schedule with periods and legal basis per category
- Query evidence showing the oldest data held per category
- Retention enforcement configuration
- Backup and archive retention arrangements
- Citations for legal retention requirements

HOW TO DOCUMENT IT

Query rather than review. Record the oldest record found in each sampled category against its stated period, expressed as the overage in years or months. That single table is usually the most actionable output of an entire privacy audit.

EXECUTIVE SUMMARY TREATMENT

Suggested language: personal data is retained beyond the organization's own stated periods across a stated number of systems, the oldest exceeding its limit by a stated number of years, increasing both regulatory exposure and the volume of data at risk in any breach.

A.1.4.9 Disposal

WHAT THE CONTROL ASKS FOR

Have documented policies and procedures for disposing of PII, and dispose of it securely so it cannot be recovered. Disposal covers all media and all copies.

WHY IT EXISTS

Deletion that leaves data recoverable has not disposed of anything. The obligation also extends to copies the organization may not have inventoried, which is why disposal depends on knowing where data lives. An unrecorded disposal also cannot be demonstrated to an individual who asked for erasure.

HOW TO AUDIT IT

1. Obtain disposal procedures and confirm they specify methods appropriate to each medium.
2. Verify disposal is evidenced, since an unrecorded deletion cannot be demonstrated.
3. Check that disposal reaches all copies, including backups, archives, non-production environments, and third parties.
4. Test a disposal by confirming the data is genuinely absent rather than flagged as deleted.
5. Check physical media and equipment disposal, linking to A.3.21.
6. Verify third-party disposal arrangements including certification and chain of custody.

EVIDENCE TO COLLECT

- Disposal policies and procedures by medium
- Disposal records for the period
- Evidence of disposal across backups and third parties
- Verification evidence that disposed data is absent
- Third-party disposal certificates

HOW TO DOCUMENT IT

Test one disposal by querying for the data afterwards. Record whether deletion is logical or physical, since data flagged deleted but still present has not been disposed of and remains within scope of any subsequent breach.

EXECUTIVE SUMMARY TREATMENT

Suggested language: data the organization reports as deleted remains present and recoverable in its systems, so erasure requests from individuals have not been fulfilled and the data remains exposed in any breach.

A.1.4.10 PII transmission controls

WHAT THE CONTROL ASKS FOR

Subject PII transmitted over networks to appropriate controls designed to ensure it reaches its intended destination and is protected in transit.

WHY IT EXISTS

Transmission is where data leaves the organization's control, and misdirection is at least as common a cause of exposure as interception. The requirement covers both: protection against interception and controls ensuring the data goes where it was meant to go.

HOW TO AUDIT IT

1. Identify transmission paths carrying PII, internal and external.
2. Verify encryption in transit is enforced rather than available, by checking configuration.
3. Examine controls against misdirection: recipient validation, address checking, and confirmation for bulk transfers.
4. Check bulk transfers and reports specifically, since a single misdirected export exposes many individuals at once.
5. Verify transmission to third parties uses agreed secure channels rather than whatever was convenient.
6. Check whether misdirection incidents occurred during the period and what followed.

EVIDENCE TO COLLECT

- Transmission path inventory carrying PII
- Encryption configuration evidence
- Recipient validation and confirmation controls
- Bulk transfer procedures
- Misdirection incident records

HOW TO DOCUMENT IT

Record controls against misdirection separately from encryption, since organizations consistently implement the second and neglect the first while the first causes more incidents. Note bulk transfer controls specifically.

EXECUTIVE SUMMARY TREATMENT

Suggested language: bulk transfers of personal data have no recipient verification step, and a stated number of misdirection incidents occurred during the period, each exposing the data of multiple individuals.

A.1.5.2 Identify basis for PII transfer between jurisdictions

WHAT THE CONTROL ASKS FOR

Identify and document the basis for any transfer of PII between jurisdictions, and ensure a valid transfer mechanism is in place before the transfer occurs.

WHY IT EXISTS

Cross-border transfer rules are among the most actively enforced areas of privacy law, and the valid mechanisms change as adequacy decisions and standard clauses are challenged and replaced. A mechanism that was valid when adopted may not be valid now, and organizations rarely revisit them.

HOW TO AUDIT IT

1. Identify all transfers by examining data flows, hosting locations, support arrangements, and sub-processor locations, rather than accepting a transfer register.
2. Include remote access from other jurisdictions, which constitutes a transfer and is routinely overlooked.
3. For each transfer, obtain the mechanism relied on and verify it is currently valid.
4. Check whether any supplementary measures required alongside the mechanism were assessed and implemented.
5. Verify the mechanism predates the transfer, comparing dates.
6. Check whether transfer arrangements were reviewed following changes in the legal position.

EVIDENCE TO COLLECT

- Data flow and hosting location documentation
- Sub-processor locations and support arrangements
- Transfer mechanisms per transfer with dates
- Transfer impact or supplementary measures assessments
- Review records following legal developments

HOW TO DOCUMENT IT

Compile transfers independently from hosting and support arrangements rather than from the register, and record transfers you found that were not registered. Record remote access arrangements separately, since these are transfers that no data flow diagram shows.

EXECUTIVE SUMMARY TREATMENT

Suggested language: personal data is accessible from a stated jurisdiction through support arrangements with no transfer mechanism in place, a transfer the organization had not identified as a transfer at all.

A.1.5.3 Countries and international organizations to which PII can be transferred

WHAT THE CONTROL ASKS FOR

Document and make available to individuals the countries and international organizations to which PII may be transferred.

WHY IT EXISTS

Individuals are entitled to know where their data goes, and the information must be specific enough to be meaningful. A notice stating that data may be transferred internationally tells the individual nothing and does not discharge the obligation.

HOW TO AUDIT IT

1. Obtain the documented list of destination countries and organizations.
2. Compare it against the transfers you identified independently under A.1.5.2 and record omissions.
3. Check that the information is actually made available to individuals, and assess its specificity.
4. Verify the list is updated when new destinations are added, comparing revision dates against sub-processor changes.
5. Check whether the safeguards applicable to each destination are also communicated where required.

EVIDENCE TO COLLECT

- Documented destination list
- Privacy notice statements on international transfers
- Sub-processor list with locations
- Revision history against sub-processor changes

HOW TO DOCUMENT IT

Compare the published destination list against the transfers you identified and record each omission by country. Note whether the notice names countries or uses a general phrase, quoting it, since the specificity is the requirement.

EXECUTIVE SUMMARY TREATMENT

Suggested language: individuals are told only that their data may be transferred internationally, while it is in fact transferred to a stated number of named countries, a stated number of which are not covered by any adequacy decision.

A.1.5.4 Records of transfer of PII

WHAT THE CONTROL ASKS FOR

Record transfers of PII to third parties, including the data transferred, the recipient, the basis, and the date.

WHY IT EXISTS

Transfer records are what allow the organization to inform recipients of corrections and erasures under A.1.3.8, to respond to access requests accurately, and to assess exposure when a recipient suffers a breach. Without them, none of those is possible.

HOW TO AUDIT IT

1. Obtain transfer records and assess whether they identify the data, the recipient, the basis, and the date.
2. Check the level of granularity. Records at category level cannot support individual-level obligations.
3. Test completeness against transfers you identified independently.
4. Verify records are retained for as long as the obligations that depend on them persist.
5. Check whether records cover automated and ongoing transfers, such as continuous integrations, which are frequently recorded once and never maintained.

EVIDENCE TO COLLECT

- Transfer records for the period
- Integration and API documentation for ongoing transfers
- Independently compiled transfer list for comparison
- Retention arrangements for transfer records

HOW TO DOCUMENT IT

Record whether transfers are logged at individual or category level, since this determines whether the dependent obligations at A.1.3.8 and A.1.3.7 can be met at all. Note ongoing automated transfers separately.

EXECUTIVE SUMMARY TREATMENT

Suggested language: transfers of personal data to third parties are recorded only at category level, so the organization cannot determine whose data a given recipient holds and cannot meet its obligations to inform recipients of corrections and erasures.

A.1.5.5 Records of PII disclosures to third parties

WHAT THE CONTROL ASKS FOR

Record disclosures of PII to third parties, including disclosures made in response to legal requests, covering what was disclosed, to whom, on what basis, and when.

WHY IT EXISTS

Disclosures to authorities and in response to legal process are the disclosures most likely to be scrutinized later and least likely to be recorded, because they are handled as one-off legal matters outside the privacy process. The record is what allows the organization to demonstrate the disclosure was lawful and proportionate.

HOW TO AUDIT IT

1. Obtain the disclosure record for the period and assess its completeness.
2. Search outside the privacy function for disclosures handled as legal matters, since these frequently never reach the record.
3. Verify each disclosure records the legal basis and the specific data disclosed.
4. Check that disclosures were assessed for lawfulness and proportionality before being made.
5. Verify individuals were notified where notification was required and not prohibited.
6. Check who is authorized to make such disclosures and whether that authority was exercised in each case.

EVIDENCE TO COLLECT

- Disclosure records for the period
- Legal department records of requests received
- Assessment records for lawfulness and proportionality
- Notification records to individuals where applicable
- Disclosure authorization matrix

HOW TO DOCUMENT IT

Search legal function records for disclosures that never reached the privacy record, and report the difference. Record whether each disclosure was assessed before being made, since disclosures made on receipt of a request without assessment are the characteristic failure here.

EXECUTIVE SUMMARY TREATMENT

Suggested language: personal data was disclosed to authorities on a stated number of occasions during the period without any assessment of whether the request was lawful or proportionate, and these disclosures appear in no privacy record.

Annex A.2: PII Processor Controls

Eighteen controls applying where the organization processes personal data on behalf of another party under that party's instructions. They cover the customer relationship (A.2.2), obligations to individuals (A.2.3), privacy by design (A.2.4), and sharing, transfer and disclosure (A.2.5).

The defining constraint of this group is A.2.2.3: customer data may be processed only for the customer's purposes. The moment the organization uses it for its own ends, whether for analytics, benchmarking, product development, or model training, it becomes a controller for that use and needs its own lawful basis, which it almost never has. Test that boundary first and test it hard.

Two further tests are worth prioritizing. Exercise the deletion capability the organization provides to its customers (A.2.3.2), because a function that flags records rather than removing them leaves every customer believing it has fulfilled erasure requests it has not. And query for data belonging to a terminated customer (A.2.4.3), because termination is when processor obligations are least likely to be completed and the customer has no way to check.

Throughout this group, reconcile against billing and accounts payable rather than against registers. Customers processed without agreements and subcontractors engaged without disclosure both show up in the ledger when they appear nowhere else.

Quick reference: A.2 Processor

Navigation: every reference and title below links to its full entry. Links shown in [orange](#) with a [cyb](#) or [ai](#) marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are [blue](#).

Ref	Title	Primary evidence
A.2.2.2 PRIV	Customer agreement	Customer register reconciled to billing records
A.2.2.3 PRIV	Organization's purposes	Inventory of all uses of customer PII
A.2.2.4 PRIV	Marketing and advertising use	Marketing database source analysis
A.2.2.5 PRIV	Infringing instruction	Instruction assessment process
A.2.2.6 PRIV	Customer obligations	Information packages provided to customers
A.2.2.7 PRIV	Records related to processing PII	Records of processing carried out as processor
A.2.3.2 PRIV	Comply with obligations to PII principals	Process for directly received requests
A.2.4.2 PRIV	Temporary files	Temporary file location inventory across the pipeline
A.2.4.3 PRIV	Return, transfer or disposal of PII	List of relationships terminated during the period
A.2.4.4 PRIV	PII transmission controls	Transmission path inventory including sub-processor routes
A.2.5.2 PRIV	Basis for PII transfer between jurisdictions	Hosting, sub-processor, and support location documentation

Ref	Title	Primary evidence
A.2.5.3 PRIV	Countries and international organizations to which PII can be transferred	Documented destination list and its publication location
A.2.5.4 PRIV	Records of PII disclosures to third parties	Disclosure records for the period
A.2.5.5 PRIV	Notification of PII disclosure requests	Disclosure request handling process
A.2.5.6 PRIV	Legally binding PII disclosures	Request validity assessment process
A.2.5.7 PRIV	Disclosure of subcontractors used to process PII	Sub-processor list with roles and locations
A.2.5.8 PRIV	Engagement of a subcontractor to process PII	Customer authorizations for sub-processing
A.2.5.9 PRIV	Change of subcontractor to process PII	Sub-processor change records for the period

A.2.2.2 Customer agreement

WHAT THE CONTROL ASKS FOR

Have a written agreement with each customer whose PII the organization processes, setting out the roles and responsibilities of both parties, the scope and nature of the processing, and the organization's obligations as processor.

WHY IT EXISTS

As a processor the organization's authority to process comes entirely from the customer's instructions, and the agreement is where those instructions are recorded. Processing outside the agreement is processing without authority, which makes the organization a controller for that activity and exposes it to obligations it has not prepared for.

HOW TO AUDIT IT

1. Identify all customers whose PII the organization processes and confirm a written agreement exists for each.
2. Sample agreements and verify they define the scope, nature, duration, and purpose of processing, and the categories of data and individuals.
3. Check that the agreement records the instructions the organization is to act on, since this is what bounds its authority.
4. Verify the agreement predates the start of processing, comparing dates.
5. Check for customers onboarded without an agreement, using billing records rather than the contract register.
6. Confirm agreements are current where the service has changed since signature.

EVIDENCE TO COLLECT

- Customer register reconciled to billing records
- Executed agreements for sampled customers
- Agreement dates against processing start dates
- Service descriptions for comparison against agreed scope
- Amendment records where the service changed

HOW TO DOCUMENT IT

Reconcile the customer register to billing records and record customers processing data without an agreement. Compare the agreed processing scope against the service actually delivered, since scope creep after signature is common and leaves the additional processing unauthorized.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization processes personal data for a stated number of customers with no written agreement, meaning it has no recorded authority for that processing and may be acting as a controller without having assumed the corresponding obligations.

A.2.2.3 Organization's purposes

WHAT THE CONTROL ASKS FOR

Ensure PII processed on behalf of a customer is processed only for the purposes expressed in the customer's documented instructions, and not for the organization's own purposes.

WHY IT EXISTS

This is the defining constraint of the processor role. The moment the organization uses customer data for its own ends, it becomes a controller for that use and needs its own lawful basis, which it almost never has. Service improvement, analytics, and model training are the uses through which this boundary is most often crossed.

HOW TO AUDIT IT

1. Identify every use the organization makes of customer PII, examining analytics, benchmarking, product development, and model training.
2. Compare each use against the customer's documented instructions and identify uses beyond them.
3. Check aggregate and de-identified use specifically, and assess whether the de-identification is sufficient to take the data outside the customer's control.
4. Verify that where the organization does use data for its own purposes, this is agreed with the customer and it has determined its own lawful basis.
5. Examine internal access to customer data by teams whose function is not service delivery.
6. Check non-production environments for customer data used in development.

EVIDENCE TO COLLECT

- Inventory of all uses of customer PII
- Customer instructions from agreements for comparison
- De-identification methods where aggregate use is claimed
- Access listings for customer data by team and function
- Non-production environment data inventory

HOW TO DOCUMENT IT

Record every use found against the instructions permitting it. Where the organization uses customer data for its own purposes, state whether the customer agreed and whether the organization has identified its own lawful basis, since both are required and one is usually missing.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization uses customer personal data to improve its own products without the customers' agreement, which makes it a controller for that processing with no lawful basis identified and no notice given to the individuals concerned.

A.2.2.4 Marketing and advertising use

WHAT THE CONTROL ASKS FOR

Do not use PII processed on behalf of a customer for the organization's own marketing or advertising purposes without the customer's express agreement, and never make provision of the service conditional on that agreement.

WHY IT EXISTS

Marketing use is singled out because it is the most tempting and most commercially valuable misuse of customer data, and because the individuals concerned have no relationship with the processor and would not expect to hear from it. The prohibition on conditioning the service prevents agreement being extracted as the price of the contract.

HOW TO AUDIT IT

1. Determine whether the organization markets to individuals whose data it processes for customers.
2. Where it does, verify express customer agreement exists and is specific to marketing rather than buried in general terms.
3. Check that the service is not conditional on that agreement, by examining whether declining is possible and what happens if a customer does.
4. Examine marketing databases for records sourced from customer processing.
5. Check contact of customer staff separately from customer end users, since the former is often assumed permissible.
6. Verify any such marketing has its own lawful basis and notice.

EVIDENCE TO COLLECT

- Marketing database source analysis
- Customer agreements containing marketing provisions
- Evidence that agreement is optional
- Lawful basis and notice for any permitted marketing

HOW TO DOCUMENT IT

Trace the source of marketing contacts to establish whether any originate from customer processing. Record whether marketing agreement is genuinely optional, with the specific contractual mechanism, since conditioning is a distinct prohibition.

EXECUTIVE SUMMARY TREATMENT

Suggested language: individuals whose data the organization processes on behalf of its customers have been added to its own marketing database without the customers' agreement and without any notice to the individuals.

A.2.2.5 Infringing instruction

WHAT THE CONTROL ASKS FOR

Inform the customer if, in the organization's opinion, an instruction infringes applicable legislation. The processor is not a neutral executor of instructions; it must recognize and raise unlawful ones.

WHY IT EXISTS

A processor that follows an unlawful instruction shares liability for the consequence. This control also protects the organization commercially, since raising the issue creates a record that it identified the problem. The practical difficulty is capability: recognizing an infringing instruction requires legal competence the organization may not have.

HOW TO AUDIT IT

1. Confirm a process exists for assessing instructions against legal requirements and for raising concerns with the customer.
2. Check who performs that assessment and whether they are competent to make a legal judgment, linking to Clause 7.2.
3. Verify the process is applied to new instructions rather than only at contract signature.
4. Examine whether any instruction was challenged during the period and what followed.
5. Check whether the organization has the contractual ability to refuse or suspend processing on an infringing instruction.
6. Confirm challenges are recorded, since the record is the protection.

EVIDENCE TO COLLECT

- Instruction assessment process
- Competence evidence for those assessing instructions
- Records of instructions received outside the original agreement
- Records of challenges raised with customers and outcomes
- Contractual rights to refuse or suspend

HOW TO DOCUMENT IT

Record whether any instruction has ever been challenged. Where none has across a substantial customer base and period, note that either the process is not operating or no assessment is occurring, and record which the evidence supports.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization has no capability to identify whether a customer instruction would be unlawful, and has never challenged one, so it is executing instructions whose lawfulness it has never assessed and for which it would share liability.

A.2.2.6 Customer obligations

WHAT THE CONTROL ASKS FOR

Provide customers with the information they need to demonstrate their own compliance, and assist them in meeting their obligations as controllers.

WHY IT EXISTS

The customer remains accountable for processing the organization performs on its behalf, and it can only discharge that accountability with information only the processor holds. Failing to provide it does not shift the obligation; it leaves the customer unable to meet an obligation it still has, which is both a contractual and a commercial problem.

HOW TO AUDIT IT

1. Identify what information the organization provides to customers about the processing it performs.
2. Check whether it is sufficient for a customer to complete its own records of processing and impact assessments.
3. Verify assistance obligations are met in practice: data subject request support, breach information, and audit cooperation.
4. Examine response times for customer requests for information and compare against contractual commitments.
5. Check whether audit or inspection rights granted to customers have ever been exercised and how the organization responded.
6. Verify the organization can identify which of a customer's individuals are affected by a given event.

EVIDENCE TO COLLECT

- Information packages provided to customers
- Contractual assistance obligations
- Records of customer requests for information with response times
- Audit or inspection requests and responses
- Evidence of data subject request assistance provided

HOW TO DOCUMENT IT

Record what the organization provides against what a controller would need to meet its own obligations, item by item. Note response times for customer information requests against contractual commitments, since these are enforceable.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization does not provide customers with the information they need to complete their own records of processing, leaving a stated number of controllers unable to meet an accountability obligation that remains theirs.

A.2.2.7 Records related to processing PII

WHAT THE CONTROL ASKS FOR

Maintain records of the processing carried out on behalf of customers, covering the categories of processing, the customers concerned, transfers, sub-processors, and security measures.

WHY IT EXISTS

The processor's records are distinct from the controller's and serve a different purpose: demonstrating what the organization does for whom, which is what a supervisory authority asks a processor for. They are also the working inventory for assessing exposure when something goes wrong.

HOW TO AUDIT IT

1. Obtain the records and test completeness against the customer register and against billing records.
2. Verify each required element is present per processing category.
3. Test accuracy by comparing a sampled entry against the actual service delivered.
4. Check that sub-processors are recorded per customer, since sub-processing arrangements frequently vary by contract.
5. Confirm transfers are recorded, including those arising from sub-processor locations.
6. Verify the records are maintained rather than produced once.

EVIDENCE TO COLLECT

- Records of processing carried out as processor
- Customer register and billing records for reconciliation
- Sub-processor listings per customer
- Transfer records arising from sub-processing
- Revision history against service changes

HOW TO DOCUMENT IT

Test one entry against the live service in detail and record divergences. Record whether sub-processors are tracked per customer or only globally, since a customer that refused a particular sub-processor cannot be served correctly from a global list.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization's records of processing do not reflect the services it actually delivers or the sub-processors it actually uses, so the document a supervisory authority would request first is inaccurate.

A.2.3.2 Comply with obligations to PII principals

WHAT THE CONTROL ASKS FOR

Provide the customer with the means to comply with its obligations to individuals, and where the organization receives a request directly, handle it in accordance with the agreement rather than responding on its own initiative.

WHY IT EXISTS

Individuals frequently contact the processor because it is the organization they can see. The processor generally has no authority to respond, and doing so risks disclosing data to someone whose identity the controller has not verified. Equally, ignoring the request leaves the controller unaware that a clock has started.

HOW TO AUDIT IT

1. Confirm a process exists for handling requests received directly from individuals, and that it routes rather than answers.
2. Verify staff can recognize such a request and know where to send it.
3. Check that the customer is notified promptly, since the statutory clock runs against them.
4. Examine the technical means provided to customers for fulfilling requests: export, correction, and deletion capability.
5. Test whether those means actually work, particularly deletion, by exercising them if permitted.
6. Check the request log for directly received requests during the period and their handling.

EVIDENCE TO COLLECT

- Process for directly received requests
- Notification records to customers with timings
- Technical capabilities provided to customers for request fulfilment
- Test evidence for export and deletion functions
- Log of directly received requests for the period

HOW TO DOCUMENT IT

Test the deletion capability provided to customers and record whether data is genuinely removed or merely flagged. A deletion function that does not delete leaves the controller unable to fulfil erasure requests while believing it can.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the deletion function the organization provides to its customers marks records as deleted without removing the data, so a stated number of controllers believe they have fulfilled erasure requests that remain unfulfilled.

A.2.4.2 Temporary files

WHAT THE CONTROL ASKS FOR

Ensure temporary files containing customer PII are deleted within a documented period. Temporary files include caches, exports, staging areas, logs, and intermediate processing outputs.

WHY IT EXISTS

Processors generate temporary files at scale as a byproduct of normal operation: integration staging, batch outputs, support exports, and diagnostic captures. These accumulate outside the retention controls applied to the primary data store and outside anything the customer can see or audit.

HOW TO AUDIT IT

1. Identify where temporary files containing customer PII are created across the processing pipeline.
2. Check whether documented deletion periods exist and are technically enforced.
3. Search actual locations rather than reviewing policy, including staging directories, support tooling, and log stores.
4. Record the age of what you find against the documented period.
5. Check support and diagnostic exports specifically, since these are created by individuals and rarely tracked.
6. Verify temporary files carry the same access controls as the source data.

EVIDENCE TO COLLECT

- Temporary file location inventory across the pipeline
- Documented deletion periods with enforcement configuration
- Directory listings with file ages and record counts
- Support export logging and controls
- Access controls on temporary locations

HOW TO DOCUMENT IT

Search actual locations and record findings with ages and volumes. Record support exports separately, since these are created ad hoc by staff, contain live customer data, and are almost never covered by any retention control.

EXECUTIVE SUMMARY TREATMENT

Suggested language: support exports containing customer personal data accumulate indefinitely in shared locations, the oldest dating from a stated period, outside every retention control the organization has committed to its customers.

A.2.4.3 Return, transfer or disposal of PII

WHAT THE CONTROL ASKS FOR

At the end of processing, return the PII to the customer, transfer it as directed, or dispose of it securely, according to the agreement, and be able to demonstrate what was done.

WHY IT EXISTS

Termination is when processor obligations are most often unmet, because the commercial relationship has ended and nobody is motivated to complete the work. Data retained after termination is retained with no authority at all, and the customer usually has no way to verify whether it was deleted.

HOW TO AUDIT IT

1. Identify customer relationships that ended during the period.
2. For each, verify the agreed return, transfer, or disposal occurred and was evidenced.
3. Check the timeframe between termination and completion against the agreement.
4. Verify disposal reached backups, archives, and sub-processors, or that the treatment of each is documented and agreed.
5. Test by querying for data belonging to a terminated customer.
6. Check whether the customer received confirmation.

EVIDENCE TO COLLECT

- List of relationships terminated during the period
- Return, transfer, or disposal records with dates
- Confirmation issued to customers
- Sub-processor disposal confirmations
- Query evidence for terminated customer data

HOW TO DOCUMENT IT

Query for data belonging to a terminated customer rather than reviewing the disposal record. Record how long after termination the data persisted, and whether sub-processors also disposed of it, since the second is rarely followed through.

EXECUTIVE SUMMARY TREATMENT

Suggested language: personal data belonging to customers whose contracts ended a stated period ago remains in the organization's systems and in those of its sub-processors, retained with no contractual or lawful authority.

A.2.4.4 PII transmission controls

WHAT THE CONTROL ASKS FOR

Subject customer PII transmitted over networks to controls ensuring it reaches its intended destination and is protected in transit.

WHY IT EXISTS

A processor transmits data on behalf of many customers, which makes misdirection disproportionately serious: a routing error can deliver one customer's data to another. Protection in transit is the expected control; controls against misdirection are the one that prevents the incident customers fear most.

HOW TO AUDIT IT

1. Identify transmission paths carrying customer PII, including to sub-processors and back to customers.
2. Verify encryption in transit is enforced by configuration rather than available by policy.
3. Examine controls preventing delivery to the wrong customer, particularly in multi-tenant processing and bulk output generation.
4. Test tenant separation in output routing where practical.
5. Check bulk transfer procedures including verification steps.
6. Review misdirection incidents during the period.

EVIDENCE TO COLLECT

- Transmission path inventory including sub-processor routes
- Encryption configuration evidence
- Output routing and tenant separation design
- Bulk transfer verification procedures
- Misdirection incident records

HOW TO DOCUMENT IT

Record controls against cross-customer misdelivery specifically, separately from encryption. This is the failure mode with the greatest commercial consequence for a processor and the one customers ask about directly.

EXECUTIVE SUMMARY TREATMENT

Suggested language: output routing has no verification step preventing one customer's data from being delivered to another, and a stated number of such incidents occurred during the period.

A.2.5.2 Basis for PII transfer between jurisdictions

WHAT THE CONTROL ASKS FOR

Inform the customer of any transfer of PII between jurisdictions, and ensure a valid transfer basis is in place. The customer, as controller, needs this information to meet its own obligations.

WHY IT EXISTS

The controller is accountable for transfers made by its processor, but can only account for them if it knows about them. Processors frequently transfer through sub-processor locations, support arrangements, and disaster recovery sites without recognizing these as transfers or telling anyone.

HOW TO AUDIT IT

1. Identify all transfers independently, including hosting, sub-processors, support access, and recovery sites.
2. Verify each was disclosed to affected customers.
3. Confirm a valid transfer mechanism is in place for each and that it predates the transfer.
4. Check remote support access from other jurisdictions specifically, since this is a transfer that appears on no diagram.
5. Verify supplementary measures were assessed where required.
6. Check that new transfers trigger customer notification.

EVIDENCE TO COLLECT

- Hosting, sub-processor, and support location documentation
- Customer notifications of transfers
- Transfer mechanisms with dates
- Transfer impact assessments
- Support access arrangements by location

HOW TO DOCUMENT IT

Compile transfers independently from support rotas and hosting arrangements, not from the register. Record transfers the organization had not identified as transfers, since remote support access is routinely missed and is the most common example.

EXECUTIVE SUMMARY TREATMENT

Suggested language: customer personal data is accessible from a stated jurisdiction through support arrangements that were never disclosed to customers and for which no transfer mechanism exists.

A.2.5.3 Countries and international organizations to which PII can be transferred

WHAT THE CONTROL ASKS FOR

Document and make available to customers the countries and international organizations to which their PII may be transferred.

WHY IT EXISTS

Customers need this to complete their own transparency obligations to individuals, and increasingly to satisfy their own regulators. Specificity matters: a statement that data may be processed globally gives the customer nothing it can pass on.

HOW TO AUDIT IT

1. Obtain the documented destination list and compare it against transfers you identified independently.
2. Check it is actually made available to customers rather than existing internally.
3. Assess specificity, since general statements do not enable the customer to meet its own obligation.
4. Verify the list is updated when destinations change, comparing revision dates against sub-processor changes.
5. Check whether customers are notified of changes or expected to monitor a webpage.

EVIDENCE TO COLLECT

- Documented destination list and its publication location
- Sub-processor list with locations
- Customer notification records for destination changes
- Revision history

HOW TO DOCUMENT IT

Compare the published list against identified transfers and record omissions by country. Note the notification mechanism for changes, since a list published on a webpage the customer is expected to monitor may not satisfy a contractual notification obligation.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the published list of processing locations omits a stated number of countries where customer data is actually accessible, so customers relying on it are giving their own individuals inaccurate information.

A.2.5.4 Records of PII disclosures to third parties

WHAT THE CONTROL ASKS FOR

Record disclosures of customer PII to third parties, covering what was disclosed, to whom, on what basis, and when.

WHY IT EXISTS

Disclosure records let the organization tell a customer exactly what left and to whom, which is what the customer needs when assessing an incident or answering its own regulator. Without them the processor can only describe categories, which is rarely enough.

HOW TO AUDIT IT

1. Obtain disclosure records and assess whether they identify the data, recipient, basis, and date.
2. Check granularity, since category-level records cannot support customer-specific answers.
3. Test completeness against sub-processor arrangements and integrations.
4. Verify records are retained as long as the customer may need them.
5. Check whether customers can obtain the records relating to their own data.

EVIDENCE TO COLLECT

- Disclosure records for the period
- Sub-processor and integration documentation
- Retention arrangements for disclosure records
- Customer access arrangements to their own records

HOW TO DOCUMENT IT

Record whether disclosures are logged at customer level, since a processor unable to say which customer's data went where cannot support any customer's incident assessment.

EXECUTIVE SUMMARY TREATMENT

Suggested language: disclosures are recorded only in aggregate, so following an incident the organization could not tell any individual customer what data of theirs had been disclosed or to whom.

A.2.5.5 Notification of PII disclosure requests

WHAT THE CONTROL ASKS FOR

Notify the customer of any legally binding request for disclosure of their PII, unless notification is prohibited.

WHY IT EXISTS

The customer is the controller and is entitled to know when an authority seeks its data, so it can assess the request and take its own position. A processor that discloses without notifying deprives the controller of any opportunity to object.

HOW TO AUDIT IT

1. Confirm a process exists for handling and notifying disclosure requests.
2. Check who receives such requests and whether they know to route them, since they typically arrive at a legal or executive address.
3. Verify notification occurred for requests received during the period, with timing.
4. Where notification was withheld, verify a legal prohibition applied and was assessed rather than assumed.
5. Check that the process allows the customer time to respond before disclosure where possible.
6. Confirm requests and notifications are recorded.

EVIDENCE TO COLLECT

- Disclosure request handling process
- Records of requests received during the period
- Customer notification records with timings
- Legal assessments where notification was withheld

HOW TO DOCUMENT IT

Record each request received, whether the customer was notified, and how long before disclosure. Where notification was withheld, record the specific legal basis for withholding, since assuming a prohibition is a common and consequential error.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization disclosed customer personal data in response to legal requests without notifying the customers concerned, and could not demonstrate that any prohibition on notification applied.

A.2.5.6 Legally binding PII disclosures

WHAT THE CONTROL ASKS FOR

Reject any request for disclosure that is not legally binding, consult the customer where permitted, and accept contractually agreed requests. Assess the validity of the request before disclosing.

WHY IT EXISTS

Not every request from an authority is legally binding, and disclosing in response to one that is not is an unauthorized disclosure. The assessment step is what distinguishes a lawful disclosure from a voluntary one made under perceived pressure.

HOW TO AUDIT IT

1. Confirm a process exists to assess whether a request is legally binding before responding.
2. Check who performs the assessment and whether they are competent to make it.
3. Examine requests received during the period and the assessment performed for each.
4. Verify any request found not to be binding was rejected.
5. Check that the organization documents the specific legal instrument relied on for each disclosure made.
6. Confirm consultation with the customer occurred where permitted.

EVIDENCE TO COLLECT

- Request validity assessment process
- Competence evidence for assessors
- Requests received with assessments and outcomes
- Legal instrument citations for disclosures made
- Customer consultation records

HOW TO DOCUMENT IT

Record for each disclosure the specific legal instrument relied on. Where the record states only that a request was received from an authority, note that the binding nature was never established and the disclosure was therefore voluntary.

EXECUTIVE SUMMARY TREATMENT

Suggested language: customer personal data was disclosed in response to requests whose legally binding nature was never assessed, making those disclosures voluntary and unauthorized under the customer agreements.

A.2.5.7 Disclosure of subcontractors used to process PII

WHAT THE CONTROL ASKS FOR

Disclose to customers the subcontractors used to process their PII, before those subcontractors are engaged.

WHY IT EXISTS

The controller remains accountable for the whole processing chain and must know who is in it. Disclosure before engagement is what gives the customer the opportunity to object, which is the point of the requirement; disclosure afterwards is a notification, not a disclosure.

HOW TO AUDIT IT

1. Obtain the sub-processor list and reconcile it against actual arrangements, including any engaged directly by operational teams.
2. Verify disclosure occurred to each affected customer and that it preceded engagement, comparing dates.
3. Check the disclosure identifies what each sub-processor does and where it is located.
4. Verify customers can determine which sub-processors touch their specific data, since a global list may not be customer-specific.
5. Check whether the list is maintained and how customers learn of changes.

EVIDENCE TO COLLECT

- Sub-processor list with roles and locations
- Accounts payable reconciliation for undisclosed sub-processors
- Disclosure records with dates against engagement dates
- Customer-specific sub-processor mapping

HOW TO DOCUMENT IT

Reconcile the disclosed list against accounts payable and record any sub-processor handling customer data that appears nowhere in the disclosure. Compare disclosure dates against engagement dates and record negative variances.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of subcontractors processing customer personal data were never disclosed to the affected customers, and a stated number were engaged before disclosure, denying customers the opportunity to object.

A.2.5.8 Engagement of a subcontractor to process PII

WHAT THE CONTROL ASKS FOR

Engage subcontractors only with the customer's authorization, and impose on them the same obligations the organization owes the customer, through a written contract.

WHY IT EXISTS

Obligations must flow down or the chain breaks: a sub-processor with weaker obligations than the processor creates a gap the controller cannot see. The organization also remains fully liable for its sub-processors, so a flow-down failure is its own exposure, not merely a compliance formality.

HOW TO AUDIT IT

1. Verify customer authorization exists for each sub-processor, whether specific or general with a right to object.
2. Sample sub-processor contracts and check that the obligations match those the organization owes its customers, term by term.
3. Check flow-down of the most consequential terms: security, breach notification timing, sub-processing, audit rights, and return or deletion.
4. Verify the organization assessed each sub-processor before engagement.
5. Check that sub-processors are monitored during the relationship, not only assessed at onboarding.
6. Confirm the organization can demonstrate the chain to a customer on request.

EVIDENCE TO COLLECT

- Customer authorizations for sub-processing
- Sub-processor contracts for the sample
- Customer agreements for term-by-term comparison
- Sub-processor assessment records with dates
- Ongoing monitoring evidence

HOW TO DOCUMENT IT

Compare sub-processor contract terms against customer contract terms in a table, marking each as matched, weakened, or absent. Weakened terms are the finding, and the table makes the gap in the chain immediately visible.

EXECUTIVE SUMMARY TREATMENT

Suggested language: obligations the organization owes its customers are not passed to its subcontractors, including breach notification timeframes, so it has committed to timelines it has no mechanism to meet.

A.2.5.9 Change of subcontractor to process PII

WHAT THE CONTROL ASKS FOR

Inform customers of any intended change of subcontractor in time for them to object, and handle objections in accordance with the agreement.

WHY IT EXISTS

A change of sub-processor changes the processing chain the controller is accountable for. Meaningful notice is what allows the customer to assess the new party and object if it has grounds. Notice given after the change, or with insufficient time to act, provides the appearance of the right without its substance.

HOW TO AUDIT IT

1. Identify sub-processor changes during the period.
2. Verify customers were informed and measure the notice period given against the agreed period.
3. Check whether the notice reached the right contact rather than being published somewhere customers were expected to monitor.
4. Verify any objections received were handled according to the agreement.
5. Check whether changes proceeded before the objection period expired.
6. Confirm the new sub-processor was assessed before the change.

EVIDENCE TO COLLECT

- Sub-processor change records for the period
- Customer notifications with dates and delivery method
- Agreed notice periods from customer contracts
- Objection records and their handling
- Assessment records for new sub-processors

HOW TO DOCUMENT IT

Record notice period given against notice period agreed, per change. Record the delivery method, since publication to a webpage may not satisfy a contractual notification requirement and this is a common substitution.

EXECUTIVE SUMMARY TREATMENT

Suggested language: subcontractor changes were made with a stated number of days notice against a contractual requirement of a stated number, and notice was published rather than delivered, so customers had no practical opportunity to object.

Annex A.3: Information Security Controls

Twenty-nine information security controls, applicable to controllers and processors alike. In the 2019 edition these came from ISO/IEC 27001, which was a prerequisite. In the 2025 standalone edition they are included directly, so an organization can certify a PIMS without an ISMS underneath it.

Every control in this group has a direct ISO/IEC 27001:2022 Annex A counterpart, named at the start of each entry. Where an ISMS is already certified, existing evidence is reusable, but only with one check performed first: confirm that the ISMS scope actually covers the PIMS scope. Since the 2025 edition sets the PIMS scope independently, the two can diverge, and reused evidence from a narrower ISMS proves nothing about processing outside it.

The audit steps here do not repeat the general security testing you would perform against ISO/IEC 27001. They focus on the additional question this standard asks: whether the control operates over personal data specifically. A classification scheme that cannot identify personal data, logging that cannot show whose record was accessed, and backups with no documented position on erasure are all controls that would pass a security audit and fail here.

A.3.31 on test information is the single highest-yield control in this group. Production personal data in development environments is simultaneously a security weakness and unlawful processing, and it is present far more often than organizations expect.

Quick reference: A.3 Security

Navigation: every reference and title below links to its full entry. Links shown in **orange** with a **CYB** or **AI** marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are **blue**.

Ref	Title	Primary evidence
A.3.3	Policies for information security	Policy set with approval dates, versions, and owners
A.3.4	Information security roles and responsibilities	Responsibility matrix covering personal data duties
A.3.5	Classification of information	Classification scheme with criteria and handling requirements
A.3.6	Labelling of information	Labelling procedures by media type
A.3.7	Information transfer	Transfer rules and procedures per channel
A.3.8	Identity management	Identity inventory or directory export
A.3.9	Access rights	Access request and approval records
A.3.10	Addressing information security within supplier agreements	Supplier agreements for the sample
A.3.11	Information security incident management planning and preparation	Incident plan with personal data breach provisions
A.3.12	Response to information security incidents	Incident records involving personal data with full timelines

Ref	Title	Primary evidence
A.3.13	Legal, statutory, regulatory and contractual requirements	Obligations register with owner and approach per entry
A.3.14	Protection of records	Privacy record inventory by type
A.3.15	Independent review of information security	Independent review reports with scope and findings
A.3.16	Compliance with policies, rules and standards for information security	Compliance checking programme with scope and frequency
A.3.17	Information security awareness, education and training	Training content covering privacy obligations
A.3.18	Confidentiality or non-disclosure agreements	Register of confidentiality agreements
A.3.19	Clear desk and clear screen	Clear desk and screen policy
A.3.20	Storage media	Media handling procedures by classification
A.3.21	Secure disposal or re-use of equipment	Disposal procedures by media type
A.3.22	User endpoint devices	Endpoint management enrollment against asset inventory
A.3.23	Secure authentication	Authentication configuration per system holding personal data
A.3.24	Information backup	Backup coverage against systems holding personal data
A.3.25	Logging	Logging configuration per system holding personal data
A.3.26	Use of cryptography	Cryptography policy with approved algorithms
A.3.27	Secure development life cycle	Development lifecycle with privacy activities per stage
A.3.28	Application security requirements	Requirements specifications with dates
A.3.29	Secure system architecture and engineering principles	Documented engineering principles including privacy
A.3.30	Outsourced development	Register of outsourced development
A.3.31	Test information	Non-production environment inventory with data held

A.3.3 Policies for information security

WHAT THE CONTROL ASKS FOR

Define, approve, publish, and review security policies covering the protection of PII. Counterpart: ISO/IEC 27001 Annex A.5.1. The PIMS question is whether the policy set actually addresses personal data, or addresses information generically and leaves privacy-specific handling unstated.

WHY IT EXISTS

Policy is the authority behind every security requirement applied to personal data. A generic information security policy set will not tell staff that personal data carries handling requirements beyond confidentiality, such as minimization and retention, which are privacy obligations that security policies do not usually express.

HOW TO AUDIT IT

1. Obtain the policy set and identify which policies address personal data specifically rather than information generally.
2. Where an ISMS is certified, confirm its policy set covers the PIMS scope and check for scope divergence.
3. Verify approval, communication, and acknowledgement coverage against a complete population including contractors.
4. Check the review cycle and whether reviews were triggered by privacy-relevant change.
5. Test two personal-data-specific requirements operationally against observed practice.

EVIDENCE TO COLLECT

- Policy set with approval dates, versions, and owners
- ISO/IEC 27001 policy set and scope where held
- Acknowledgement records reconciled to full population
- Review log with scheduled and actual dates

HOW TO DOCUMENT IT

Record which policies address PII specifically and which are generic. Where an ISMS is relied on, record the scope comparison, since reused evidence is only valid where the scopes align.

EXECUTIVE SUMMARY TREATMENT

Suggested language: security policies address information generically and impose no requirements specific to personal data, so staff receive no instruction on the handling obligations that apply to it beyond keeping it confidential.

A.3.4 Information security roles and responsibilities

WHAT THE CONTROL ASKS FOR

Define and allocate security roles and responsibilities relevant to protecting PII. Counterpart: ISO/IEC 27001 Annex A.5.2. The PIMS question is whether responsibility for personal data specifically is assigned, including to the asset owners who decide who may access it.

WHY IT EXISTS

Personal data crosses functional boundaries and its protection depends on people who are not in the security function. Undefined responsibility means the duties that matter for privacy, particularly access decisions and retention enforcement, are performed by whoever happens to care.

HOW TO AUDIT IT

1. Obtain the allocation and confirm it covers operational duties over personal data, not only governance roles.
2. Sample duties that commonly go unassigned: access recertification for systems holding PII, retention enforcement, and export approval.
3. Confirm named owners and verify with each that they know they own it.
4. Cross-check assignments against the current employee directory.
5. Test one duty for actual performance, since assigned-but-unperformed is a distinct finding.

EVIDENCE TO COLLECT

- Responsibility matrix covering personal data duties
- System owner assignments for systems holding PII
- Current employee directory for reconciliation
- Performance records for sampled duties

HOW TO DOCUMENT IT

Record duty, documented owner, owner confirmed, and evidence of recent performance in a table. List duties with no identifiable owner separately.

EXECUTIVE SUMMARY TREATMENT

Suggested language: no one is assigned responsibility for enforcing retention on systems holding personal data, and consequently retention has never been applied to a stated number of them.

A.3.5 Classification of information

WHAT THE CONTROL ASKS FOR

Classify information according to security needs based on confidentiality, integrity, and availability requirements. Counterpart: ISO/IEC 27001 Annex A.5.12. The PIMS question is whether personal data is identifiable as a class, and whether special categories are distinguished.

WHY IT EXISTS

Protection cannot track sensitivity if personal data is not identifiable within the classification scheme. A scheme with levels such as internal and confidential, applied without regard to whether data is personal, cannot drive the handling differences that privacy obligations require.

HOW TO AUDIT IT

1. Obtain the scheme and check whether personal data is identifiable within it, and whether special or sensitive categories are distinguished.
2. Verify handling requirements attached to each level address privacy obligations, not only confidentiality.
3. Test application by independently classifying a sample of assets and comparing to recorded classifications.
4. Check consistency across systems holding the same data.
5. Verify reclassification occurs, particularly where data has been de-identified.

EVIDENCE TO COLLECT

- Classification scheme with criteria and handling requirements
- Asset inventory showing classifications
- Sample assets for independent classification
- Reclassification records

HOW TO DOCUMENT IT

Record your independent classification against the recorded one, with the disagreement rate. State explicitly whether the scheme can identify personal data at all, since that determines whether it can support any privacy control.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the classification scheme cannot distinguish personal data from other information, so protection and handling do not vary according to privacy obligations and special category data receives no additional protection.

A.3.6 Labelling of information

WHAT THE CONTROL ASKS FOR

Implement procedures for labelling information in line with the classification scheme, across all media. Counterpart: ISO/IEC 27001 Annex A.5.13. The PIMS question is whether personal data is visibly marked so that handling decisions can be made at the point of use.

WHY IT EXISTS

A classification nobody can see changes no behaviour. Labels are what allow a person handling an export or an email attachment to know it contains personal data, and what allows technical controls to act on it.

HOW TO AUDIT IT

1. Obtain labelling procedures and confirm coverage of the media actually in use.
2. Sample documents, emails, and exports from live locations and check labelling coverage.
3. Verify labels survive transformation: forwarding, format conversion, and export from systems.
4. Check whether labelling is enforced or voluntary, since voluntary labelling produces low coverage.
5. Include physical output during a walkthrough, recording date, time, and location.

EVIDENCE TO COLLECT

- Labelling procedures by media type
- Sample of labelled and unlabelled items from live locations
- Labelling tool configuration where automated
- Walkthrough observations

HOW TO DOCUMENT IT

Record labelling coverage as a measured percentage from your own sample, with the sample size and source. Note any transformation that strips labels, naming the operation.

EXECUTIVE SUMMARY TREATMENT

Suggested language: exports containing personal data carry no marking, so staff handling them have no way to know they require privacy-specific handling and technical controls cannot act on them.

A.3.7 Information transfer

WHAT THE CONTROL ASKS FOR

Establish rules, procedures, and agreements for transferring information, covering electronic, physical, and verbal transfer. Counterpart: ISO/IEC 27001 Annex A.5.14. The PIMS question is whether transfers of personal data are controlled and recorded, which supports A.1.5.4 and A.2.5.4.

WHY IT EXISTS

Transfer is where personal data leaves the organization's control, and it is also where the disclosure records required elsewhere in the standard originate. Uncontrolled transfer channels produce undisclosed and unrecorded transfers.

HOW TO AUDIT IT

1. Identify transfer channels actually in use, including unsanctioned ones, by asking staff how they send large files.
2. Verify protection requirements per channel are appropriate to personal data.
3. Check transfer agreements exist with recipients who regularly receive personal data.
4. Verify encryption in transit is enforced by configuration rather than stated in policy.
5. Address verbal transfer, including caller identity verification before disclosing personal data.
6. Test identity verification on a support channel if one exists.

EVIDENCE TO COLLECT

- Transfer rules and procedures per channel
- List of channels in use including unsanctioned
- Encryption configuration evidence
- Caller verification procedures and test results

HOW TO DOCUMENT IT

List channels found, marked sanctioned or unsanctioned, with protection applied. Where you tested caller verification, record exactly what you asked and what was disclosed.

EXECUTIVE SUMMARY TREATMENT

Suggested language: personal data is routinely sent through file transfer services the organization has no agreement with and no visibility of, producing transfers that appear in no disclosure record.

A.3.8 Identity management

WHAT THE CONTROL ASKS FOR

Manage the full lifecycle of identities so that every identity is traceable to a person or defined entity. Counterpart: ISO/IEC 27001 Annex A.5.16. The PIMS question is whether access to personal data can be attributed to an accountable individual.

WHY IT EXISTS

Attribution is what makes access to personal data auditable. An identity that cannot be traced to a person means no access it performs can be explained to an individual asking who looked at their data.

HOW TO AUDIT IT

1. Reconcile the identity inventory against human resources records and the contractor register.
2. Identify orphaned identities and report the count and the age of the oldest.
3. Verify every non-human identity with access to personal data has a named human owner.
4. Measure the interval between termination and identity disablement.
5. Check dormant accounts with access to systems holding personal data.

EVIDENCE TO COLLECT

- Identity inventory or directory export
- Human resources active listing and contractor register
- Service account register with owners
- Leaver list with disablement dates

HOW TO DOCUMENT IT

Present the reconciliation as counts with unmatched identities banded by age. Restrict the analysis to systems holding personal data where you can, since that focuses the finding on the PIMS scope.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of active accounts with access to personal data belong to no identifiable person, so access to that data cannot be attributed and could not be explained to the individuals concerned.

A.3.9 Access rights

WHAT THE CONTROL ASKS FOR

Provision, review, modify, and remove access rights in line with the access control policy. Counterpart: ISO/IEC 27001 Annex A.5.18. The PIMS question is whether access to personal data is limited to those who need it for the identified purposes.

WHY IT EXISTS

Broad internal access to personal data is processing beyond need, which is a privacy failure independent of any breach. Access review is the only mechanism that catches accumulation, and its quality is visible from the revocation rate alone.

HOW TO AUDIT IT

1. Sample access grants to systems holding personal data and verify documented authorization by someone with authority.
2. Verify access reviews occurred at the stated frequency and calculate the revocation rate.
3. Re-perform one review against the underlying permissions and record items you would have questioned.
4. Measure revocation timeliness for leavers across all systems holding personal data.
5. Test role changes specifically, confirming prior access was removed.

EVIDENCE TO COLLECT

- Access request and approval records
- Access review records with revocation counts
- Permission extracts for re-performance
- Leaver list with per-system revocation timestamps

HOW TO DOCUMENT IT

Report the revocation rate as a computed figure with the population. Record how many people can access each significant personal data store, since that number is the practical measure of exposure.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of staff can access the organization's principal store of personal data, which is a stated proportion of the workforce and far exceeds the number whose role requires it.

A.3.10 Addressing information security within supplier agreements

WHAT THE CONTROL ASKS FOR

Agree specific security requirements with suppliers in the agreement itself. Counterpart: ISO/IEC 27001 Annex A.5.20. The PIMS question is whether agreements with suppliers handling personal data carry the terms privacy law requires, which go beyond security.

WHY IT EXISTS

Contract terms are the only mechanism compelling a supplier to act. For personal data the required terms are prescribed rather than negotiable, and this control is where the security terms sit alongside the processing terms required by A.1.2.7.

HOW TO AUDIT IT

1. Sample supplier agreements covering suppliers who handle personal data.
2. Check for the terms that matter after an incident: breach notification with a defined timeframe, audit rights, sub-processing restrictions, and return or destruction.
3. Verify notification timeframes are short enough to let the organization meet its own regulatory deadline.
4. Check that requirements are proportionate to the data the supplier holds.
5. Confirm agreements are current where the service has changed.

EVIDENCE TO COLLECT

- Supplier agreements for the sample
- Standard security schedule or template
- Breach notification timeframes per agreement
- Supplier register with data held per supplier

HOW TO DOCUMENT IT

Present a table of supplier against required term, marked present, absent, or weakened. Record notification timeframes against the organization's own regulatory deadline, since a supplier deadline longer than the organization's own makes the deadline unachievable.

EXECUTIVE SUMMARY TREATMENT

Suggested language: suppliers holding personal data are required to notify the organization of a breach within a period longer than the organization's own regulatory deadline, so the organization cannot meet its notification obligation even if the supplier complies.

A.3.11 Information security incident management planning and preparation

WHAT THE CONTROL ASKS FOR

Plan and prepare for incident management with defined processes, roles, and responsibilities. Counterpart: ISO/IEC 27001 Annex A.5.24. The PIMS question is whether the plan addresses personal data breaches specifically, which carry statutory notification deadlines security incidents do not.

WHY IT EXISTS

Personal data breach notification operates on clocks measured in hours and requires a determination of risk to individuals that a security incident process does not make. A plan that treats a breach as an ordinary security incident will miss both.

HOW TO AUDIT IT

1. Obtain the plan and verify it addresses personal data breaches as a distinct category with their own assessment and notification path.
2. Check that the assessment of risk to individuals is defined and that someone is named to make it.
3. Verify notification deadlines per jurisdiction are recorded and correct.
4. Confirm the decision authority is available out of hours, since the clock does not pause.
5. Check the plan has been exercised with a personal data breach scenario specifically.
6. Verify the organization could identify affected individuals, which depends on logging and records of processing.

EVIDENCE TO COLLECT

- Incident plan with personal data breach provisions
- Risk-to-individuals assessment criteria
- Notification deadlines per jurisdiction
- Exercise records including a breach scenario
- Out of hours decision arrangements

HOW TO DOCUMENT IT

Record whether personal data breaches are handled as a distinct category with their own clock. Record whether the organization could identify affected individuals, since a notification obligation cannot be met without that.

EXECUTIVE SUMMARY TREATMENT

Suggested language: personal data breaches are handled through the general security incident process with no assessment of risk to individuals and no awareness of the notification deadlines that apply, so a breach would be notified late or not at all.

A.3.12 Response to information security incidents

WHAT THE CONTROL ASKS FOR

Respond to incidents in accordance with documented procedures. Counterpart: ISO/IEC 27001 Annex A.5.26. The PIMS question is whether responses to incidents involving personal data met the notification and assessment obligations within their deadlines.

WHY IT EXISTS

Response quality determines whether statutory deadlines are met. Because those deadlines run from awareness rather than from confirmation, delay in assessment consumes the notification window before anyone has decided whether to notify.

HOW TO AUDIT IT

1. Select incidents involving personal data from the period and reconstruct the response from records.
2. Measure the interval from awareness to breach determination, and from determination to notification, against the applicable deadline.
3. Verify the risk to individuals was assessed and recorded, not assumed.
4. Check whether affected individuals were notified where required, and how they were identified.
5. Verify records were made contemporaneously by examining timestamps.
6. Check whether any incident involving personal data was closed without a breach determination being made.

EVIDENCE TO COLLECT

- Incident records involving personal data with full timelines
- Breach determination records with reasoning
- Notification records with timings against deadlines
- Affected individual identification evidence

HOW TO DOCUMENT IT

Build a timeline per incident with the statutory clock overlaid, showing awareness, determination, and notification against the deadline. That overlay is what converts an incident record into a compliance finding.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a personal data breach during the period was notified a stated number of hours after the applicable deadline, and the delay arose entirely from the time taken to determine whether it was a breach at all.

A.3.13 Legal, statutory, regulatory and contractual requirements

WHAT THE CONTROL ASKS FOR

Identify, document, and keep current the legal, statutory, regulatory, and contractual requirements relevant to protecting PII, and the approach to meeting each. Counterpart: ISO/IEC 27001 Annex A.5.31.

WHY IT EXISTS

Privacy obligations arrive from multiple jurisdictions simultaneously and change frequently. Without a maintained register, obligations are discovered when they are breached, and the register is also the evidence that the organization knows what applies to it.

HOW TO AUDIT IT

1. Obtain the register and assess completeness against the jurisdictional analysis at Clause 4.1.
2. Confirm entries state the specific requirement rather than naming a law.
3. Verify each obligation is mapped to how it is met, naming a control, process, or accepted gap.
4. Check currency by identifying regulatory developments in the period and confirming the register reflects them.
5. Sample obligations and test compliance in practice rather than accepting the register's status.
6. Check contractual privacy obligations, which are usually the weakest part.

EVIDENCE TO COLLECT

- Obligations register with owner and approach per entry
- Jurisdictional analysis for comparison
- Contractual privacy obligations extracted from agreements
- Horizon scanning or legal update arrangements

HOW TO DOCUMENT IT

Name specific obligations you identified that are absent from the register, with their source. Record the last register update against regulatory developments that postdate it.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization does not maintain a current record of the privacy obligations that apply to it, and a stated number identified during this review, including a named regulatory development, are tracked nowhere.

A.3.14 Protection of records

WHAT THE CONTROL ASKS FOR

Protect records from loss, destruction, falsification, unauthorized access, and unauthorized release, for their full retention period. Counterpart: ISO/IEC 27001 Annex A.5.33. The PIMS question includes the privacy records themselves: consent, requests, and disclosures.

WHY IT EXISTS

Privacy records are the evidence of compliance. Consent records, request logs, and disclosure records are what demonstrate that obligations were met, and they contain personal data of their own. Losing them means losing the ability to demonstrate anything.

HOW TO AUDIT IT

1. Identify the record types the PIMS depends on: consent, requests, disclosures, transfers, and assessments.
2. Verify integrity protection for records where falsification would matter, particularly consent.
3. Check access controls proportionate to the personal data these records contain.
4. Verify retention is long enough to support demonstration after the processing has ended.
5. Check backup and recovery covers privacy records.
6. Test retrieval by requesting a record from a specified past date.

EVIDENCE TO COLLECT

- Privacy record inventory by type
- Integrity and access controls for each
- Retention schedule for privacy records
- Backup evidence and retrieval test results

HOW TO DOCUMENT IT

Record the retrieval test with the record requested and the outcome. Note whether privacy records are access-controlled proportionate to the personal data they contain, since they are frequently treated as administrative rather than sensitive.

EXECUTIVE SUMMARY TREATMENT

Suggested language: consent records cannot be retrieved for periods before a stated date, so the organization cannot demonstrate the lawful basis for processing personal data collected before then.

A.3.15 Independent review of information security

WHAT THE CONTROL ASKS FOR

Review the organization's approach to managing information security independently at planned intervals and on significant change. Counterpart: ISO/IEC 27001 Annex A.5.35.

WHY IT EXISTS

Independent review surfaces the problems the organization has stopped being able to see. For a PIMS the scope question matters: a security review that never examines whether personal data is over-collected or over-retained has not reviewed the privacy position at all.

HOW TO AUDIT IT

1. Confirm independent reviews occurred at defined intervals and that the last was on schedule.
2. Test independence rigorously, including whether reviewers implement the controls they review.
3. Check scope. Confirm the review covered the approach to protecting personal data, not only technical security testing.
4. Verify findings reached management at an appropriate level.
5. Track prior findings to closure and record open items with their age.

EVIDENCE TO COLLECT

- Independent review reports with scope and findings
- Reviewer independence evidence and reporting lines
- Management reporting evidence with dates
- Prior finding tracking

HOW TO DOCUMENT IT

Record the reviewer's relationship to the reviewed function explicitly. Record whether the scope covered privacy-specific matters, since substituting technical security testing for a review of the approach is the characteristic failure.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization's only independent assessment is technical penetration testing, so its approach to protecting personal data has never been independently reviewed.

A.3.16 Compliance with policies, rules and standards for information security

WHAT THE CONTROL ASKS FOR

Regularly review compliance with the organization's own security policies, rules, and standards. Counterpart: ISO/IEC 27001 Annex A.5.36.

WHY IT EXISTS

Policies drift out of practice quietly. Regular checking detects the drift while it is small, and for privacy it is the mechanism that catches requirements such as retention and minimization that have been quietly abandoned as inconvenient.

HOW TO AUDIT IT

1. Confirm a compliance checking programme exists with defined scope, frequency, and performers.
2. Verify checks cover privacy-relevant requirements, not only those that are easy to check automatically.
3. Sample completed checks and re-perform a subset to verify accuracy.
4. Check that non-compliance found is recorded, actioned, and followed up.
5. Look for repeated non-compliance in the same area, which may indicate an impractical requirement.

EVIDENCE TO COLLECT

- Compliance checking programme with scope and frequency
- Completed check records with dates and performers
- Non-compliance records with actions and closure
- Trend data across periods

HOW TO DOCUMENT IT

Record your re-performance against the organization's reported result. Discrepancy undermines the whole programme and is a more serious finding than absence.

EXECUTIVE SUMMARY TREATMENT

Suggested language: compliance with the organization's own privacy requirements is not checked, so requirements including retention have quietly stopped being followed with no mechanism to detect it.

A.3.17 Information security awareness, education and training

WHAT THE CONTROL ASKS FOR

Provide awareness, education, and training relevant to job function, updated regularly. Counterpart: ISO/IEC 27001 Annex A.6.3. The PIMS question is whether training covers privacy obligations, which differ from security obligations.

WHY IT EXISTS

Most personal data is handled by people whose job is something else, and the failures that matter are ordinary: an over-broad export, a form collecting too much, a request not recognized. Security training does not cover any of those.

HOW TO AUDIT IT

1. Confirm content covers privacy obligations distinctly from security, including minimization, retention, and individual rights.
2. Verify role-specific content for functions handling high volumes of personal data.
3. Check completion across a complete population including contractors.
4. Test effect by asking staff scenario questions rather than checking completion.
5. Verify staff can recognize a request from an individual, since unrecognized requests start clocks nobody knows about.
6. Check content currency.

EVIDENCE TO COLLECT

- Training content covering privacy obligations
- Completion records reconciled to full population
- Role-specific content for high-volume functions
- Assessment results if used

HOW TO DOCUMENT IT

Record completion by population segment rather than as a single figure. Record scenario question responses, particularly on recognizing individual requests.

EXECUTIVE SUMMARY TREATMENT

Suggested language: staff receive security training that does not address privacy obligations, and a stated proportion of those sampled could not recognize a request from an individual exercising their rights.

A.3.18 Confidentiality or non-disclosure agreements

WHAT THE CONTROL ASKS FOR

Identify, document, review, and have signed confidentiality agreements reflecting the organization's protection needs. Counterpart: ISO/IEC 27001 Annex A.6.6.

WHY IT EXISTS

Confidentiality agreements are what make personal data legally protected when shared with parties outside an employment relationship. Their absence leaves the organization with no recourse if personal data is misused by someone it gave access to.

HOW TO AUDIT IT

1. Confirm the organization has identified where agreements are required and maintains a record.
2. Sample agreements and check they define the protected information with enough specificity.
3. Verify duration is appropriate, since agreements expiring while the data remains sensitive provide protection that runs out.
4. Check signature dates against first disclosure dates.
5. Verify contractors and temporary staff with access to personal data are covered.

EVIDENCE TO COLLECT

- Register of confidentiality agreements
- Signed agreements for the sample
- Signature dates against disclosure dates
- Contractor agreement coverage

HOW TO DOCUMENT IT

Record signature date against first disclosure date per sampled relationship. Record any party with access to personal data and no agreement at all.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of contractors with access to personal data have no confidentiality obligation, so the organization has no legal recourse if they misuse the data they can reach.

A.3.19 Clear desk and clear screen

WHAT THE CONTROL ASKS FOR

Define and enforce clear desk rules for papers and removable media and clear screen rules for processing facilities. Counterpart: ISO/IEC 27001 Annex A.7.7.

WHY IT EXISTS

This addresses personal data sitting in plain sight, visible to cleaners, contractors, visitors, and colleagues with no need to know. An unlocked screen belonging to someone with access to personal data is a complete bypass of every access control.

HOW TO AUDIT IT

1. Perform an unannounced walkthrough outside core hours and record what is visible.
2. Count and categorize findings, distinguishing items containing personal data.
3. Check meeting rooms, printers, and shared spaces, which are consistently worse than individual desks.
4. Verify automatic screen locking is enforced technically and check the timeout.
5. Check secure storage availability against headcount, since insufficient storage makes compliance impossible.
6. Repeat on a second date to establish whether findings are typical.

EVIDENCE TO COLLECT

- Clear desk and screen policy
- Walkthrough records with date, time, area, and itemized observations
- Screen lock configuration across the estate
- Secure storage provision assessment

HOW TO DOCUMENT IT

Record observations by area with counts, distinguishing items containing personal data. Repeat on a second date and state whether the result is representative.

EXECUTIVE SUMMARY TREATMENT

Suggested language: an evening walkthrough found documents containing the personal data of a stated number of individuals left visible in areas accessible to cleaning and contractor staff, alongside a stated number of unlocked workstations.

A.3.20 Storage media

WHAT THE CONTROL ASKS FOR

Manage storage media through acquisition, use, transport, and disposal in line with classification and handling requirements. Counterpart: ISO/IEC 27001 Annex A.7.10.

WHY IT EXISTS

Media concentrates large volumes of personal data in small portable objects and survives the systems that created it. A single removable drive can carry the personal data of an entire customer base out of the building unrecorded.

HOW TO AUDIT IT

1. Identify media types in use, including personally owned removable media if permitted or not prevented.
2. Test whether removable media control is enforced by attempting to write a file, with authorization.
3. Verify encryption of media holding personal data is enforced rather than optional.
4. Check transport arrangements including tracking and encryption in transit.
5. Trace a sample of media to disposal and verify the record exists.

EVIDENCE TO COLLECT

- Media handling procedures by classification
- Removable media control configuration and test results
- Media inventory with content classification
- Disposal records reconciled to inventory

HOW TO DOCUMENT IT

Test removable media control practically rather than reviewing configuration, and record the result. Record any media that cannot be accounted for.

EXECUTIVE SUMMARY TREATMENT

Suggested language: removable media use is unrestricted, so any workstation can copy the personal data it can reach onto a device that leaves the building unrecorded.

A.3.21 Secure disposal or re-use of equipment

WHAT THE CONTROL ASKS FOR

Verify that equipment containing storage media has had all sensitive information removed or securely overwritten before disposal or re-use. Counterpart: ISO/IEC 27001 Annex A.7.14. This also supports the disposal obligation at A.1.4.9.

WHY IT EXISTS

Disposed equipment leaves permanently and standard deletion does not remove data. Re-use within the organization matters equally: a device passed between users may carry its predecessor's access to personal data with it.

HOW TO AUDIT IT

1. Obtain the disposal procedure and confirm the sanitization method suits the media type.
2. Verify the verification step exists and is performed by someone other than the eraser.
3. Reconcile the asset inventory to disposal records and identify equipment that left without a record.
4. Check third-party disposal certificates identify assets by serial number.
5. Check the re-use path, which is usually less controlled than disposal.

EVIDENCE TO COLLECT

- Disposal procedures by media type
- Asset inventory reconciled to disposal records
- Destruction certificates with serial numbers
- Re-use sanitization records

HOW TO DOCUMENT IT

Present the reconciliation as counts with the unexplained difference stated. Record whether certificates identify individual assets, since a certificate for a quantity proves nothing about any device.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of devices left the asset inventory with no disposal record, so the organization cannot demonstrate that personal data they held was destroyed, and cannot confirm this to individuals who requested erasure.

A.3.22 User endpoint devices

WHAT THE CONTROL ASKS FOR

Protect information stored on, processed by, or accessible through user endpoint devices. Counterpart: ISO/IEC 27001 Annex A.8.1.

WHY IT EXISTS

Endpoints are where users meet personal data and they leave the building routinely. An unencrypted, unmanaged laptop holding personal data is a notifiable breach waiting for a taxi.

HOW TO AUDIT IT

1. Establish the endpoint population from management tooling and compare against the asset inventory.
2. Report encryption, endpoint protection, and patch currency as separate coverage figures.
3. Identify unmanaged devices with access to personal data and quantify what they can reach.
4. Check whether personal data can be stored locally and whether that is controlled.
5. Verify remote wipe capability exists and has been tested.

EVIDENCE TO COLLECT

- Endpoint management enrollment against asset inventory
- Encryption and protection coverage reports
- Unmanaged device listing with access held
- Remote wipe test evidence

HOW TO DOCUMENT IT

Report each protective measure as a separate percentage rather than a combined score. List non-compliant devices individually with the personal data their user can access.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of devices holding personal data are not encrypted or centrally managed, so the organization could neither secure nor erase them if lost, and any loss would be a notifiable breach.

A.3.23 Secure authentication

WHAT THE CONTROL ASKS FOR

Implement secure authentication technologies and procedures based on access restrictions and the access control policy. Counterpart: ISO/IEC 27001 Annex A.8.5.

WHY IT EXISTS

Credential compromise remains the leading route to unauthorized access, and for personal data the consequence is a breach affecting people who had no involvement in the failure. Authentication strength should track what the access permits.

HOW TO AUDIT IT

1. Map authentication mechanisms across systems holding personal data and identify any relying on a password alone.
2. Verify multi-factor coverage and enumerate exceptions, checking whether exceptions correlate with privilege.
3. Check authentication for remote and administrative access to personal data stores.
4. Review lockout and rate limiting.
5. Check legacy authentication protocols that bypass modern controls.

EVIDENCE TO COLLECT

- Authentication configuration per system holding personal data
- Multi-factor coverage with exception list and privilege level
- Legacy protocol status
- Session and lockout configuration

HOW TO DOCUMENT IT

List multi-factor exceptions individually with the privilege level of each exempt account and the personal data it can reach.

EXECUTIVE SUMMARY TREATMENT

Suggested language: administrative access to the organization's principal store of personal data can be obtained with a password alone for a stated number of accounts.

A.3.24 Information backup

WHAT THE CONTROL ASKS FOR

Maintain and regularly test backup copies in line with an agreed backup policy. Counterpart: ISO/IEC 27001 Annex A.8.13. The PIMS question includes whether backups are covered by retention and erasure obligations.

WHY IT EXISTS

Backups protect availability but complicate privacy, because they retain personal data the organization has deleted elsewhere. The organization needs a documented, defensible position on how retention and erasure apply to backups, and most have never formed one.

HOW TO AUDIT IT

1. Verify backup coverage against the inventory of systems holding personal data.
2. Distinguish backup completion from restoration testing rigorously.
3. Check backup isolation: whether backups can be reached and deleted from production.
4. Verify backups are encrypted and access-controlled proportionate to the personal data they contain.
5. Examine the documented position on retention and erasure in backups, and whether it has been communicated to individuals or customers.

EVIDENCE TO COLLECT

- Backup coverage against systems holding personal data
- Restoration test records with dates and outcomes
- Backup encryption and access configuration
- Documented position on erasure and retention in backups

HOW TO DOCUMENT IT

Record the documented backup position on erasure. Where none exists, state that the organization cannot answer how it fulfils erasure requests in respect of backed-up data, which is a question it will eventually be asked.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization has no documented position on how erasure requests apply to personal data held in backups, so data individuals have asked it to delete persists for a stated period with no assessment of whether that is lawful.

A.3.25 Logging

WHAT THE CONTROL ASKS FOR

Produce, store, protect, and analyse logs recording activities, exceptions, faults, and relevant events. Counterpart: ISO/IEC 27001 Annex A.8.15. The PIMS question is whether access to personal data is logged, and whether the logs are themselves personal data.

WHY IT EXISTS

Logging access to personal data is what allows the organization to answer who looked at an individual's record, which is a question individuals and regulators do ask. Logs are also personal data in their own right and are frequently retained far longer than the data they describe.

HOW TO AUDIT IT

1. Verify access to personal data is logged, with sufficient content to identify who accessed whose record.
2. Check gaps, particularly on systems holding sensitive categories.
3. Verify log protection so that administrators cannot alter records of their own access.
4. Check retention against both investigative need and the fact that logs contain personal data.
5. Test completeness by generating an access event and confirming it appears.
6. Confirm logs are analysed rather than only stored.

EVIDENCE TO COLLECT

- Logging configuration per system holding personal data
- Sample log records showing content
- Log protection and retention configuration
- Test event evidence

HOW TO DOCUMENT IT

Record whether a log entry would identify who accessed a specific individual's record. Note log retention against the retention of the underlying data, since logs outliving the data they describe is a common and unexamined over-retention.

EXECUTIVE SUMMARY TREATMENT

Suggested language: access to personal data is not logged in a form that identifies whose record was accessed, so the organization could not tell an individual who has looked at their data, and its logs are retained longer than the data they describe.

A.3.26 Use of cryptography

WHAT THE CONTROL ASKS FOR

Define and implement rules for effective use of cryptography including key management. Counterpart: ISO/IEC 27001 Annex A.8.24.

WHY IT EXISTS

Encryption is a recognized mitigating factor in breach assessment, but only where the keys were not also compromised. Key management stored alongside the data it protects provides no mitigation and no defence.

HOW TO AUDIT IT

1. Obtain the cryptography policy and check approved algorithms and key lengths against current guidance.
2. Verify implementation against policy by examining configurations, including protocol versions.
3. Examine key management: generation, storage, access, rotation, and destruction.
4. Check who can access keys and whether that is separated from access to the data.
5. Verify certificate inventory and expiry tracking.

EVIDENCE TO COLLECT

- Cryptography policy with approved algorithms
- Configuration evidence for protocols and ciphers
- Key management procedures and access lists
- Certificate inventory with expiry dates

HOW TO DOCUMENT IT

Record where keys are stored relative to the data they protect and who can access both, since that relationship determines whether the encryption would mitigate a breach at all.

EXECUTIVE SUMMARY TREATMENT

Suggested language: encryption keys are stored in the same environment as the personal data they protect and accessible to the same administrators, so the encryption would not mitigate a breach of that environment and could not be relied on to reduce notification obligations.

A.3.27 Secure development life cycle

WHAT THE CONTROL ASKS FOR

Establish and apply rules for the secure development of software and systems. Counterpart: ISO/IEC 27001 Annex A.8.25. The PIMS question is whether privacy requirements enter development alongside security requirements.

WHY IT EXISTS

Privacy by design is a legal obligation in many jurisdictions and it is discharged, if at all, in the development lifecycle. A lifecycle with security gates and no privacy gates will produce systems that are secure and non-compliant.

HOW TO AUDIT IT

1. Obtain the lifecycle definition and identify where privacy requirements enter, distinct from security.
2. Verify privacy activities actually occur by sampling recent development for their outputs.
3. Check that the rules cover all development, including contractor and business-unit work.
4. Verify developers are trained in privacy by design, not only secure coding.
5. Check whether privacy review has ever changed a design.

EVIDENCE TO COLLECT

- Development lifecycle with privacy activities per stage
- Evidence of privacy activity outputs for sampled work
- Developer privacy training records
- Records of designs changed following privacy review

HOW TO DOCUMENT IT

Record which privacy activities produced evidence and which did not, by stage. Record whether privacy review has ever changed a design, since a review that never changes anything is not a gate.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the development lifecycle contains security gates but no privacy gates, so privacy by design, which is a legal obligation, is not implemented in the process where it would have to be.

A.3.28 Application security requirements

WHAT THE CONTROL ASKS FOR

Identify, specify, and approve security requirements when developing or acquiring applications. Counterpart: ISO/IEC 27001 Annex A.8.26. The PIMS question is whether privacy requirements are specified alongside them.

WHY IT EXISTS

Requirements determine what gets built. Privacy properties not stated as requirements will not be delivered, and for acquired applications the point of purchase is the last moment they can be negotiated.

HOW TO AUDIT IT

1. Sample applications, developed and acquired, and verify requirements were defined before build or purchase.
2. Check requirements cover privacy properties: data minimization, retention enforcement, consent capture, request fulfilment, and logging of access.
3. Verify requirements were approved by an accountable party.
4. Check delivered applications were verified against them.
5. For acquired applications, check whether privacy requirements formed part of selection criteria.

EVIDENCE TO COLLECT

- Requirements specifications with dates
- Privacy requirements per application
- Approval records
- Procurement selection criteria

HOW TO DOCUMENT IT

Compare requirement definition dates against build or purchase dates. Record specifically whether retention enforcement and request fulfilment were specified, since applications without them make those obligations manual forever.

EXECUTIVE SUMMARY TREATMENT

Suggested language: applications processing personal data were acquired without any requirement for retention enforcement or erasure capability, so those obligations must now be met manually for the life of the system.

A.3.29 Secure system architecture and engineering principles

WHAT THE CONTROL ASKS FOR

Establish, document, maintain, and apply principles for engineering secure systems. Counterpart: ISO/IEC 27001 Annex A.8.27. The PIMS question is whether the principles include privacy principles such as minimization and separation.

WHY IT EXISTS

Principles produce consistency across systems. Privacy principles in particular need to be architectural, because minimization and separation are design properties that cannot be retrofitted cheaply.

HOW TO AUDIT IT

1. Obtain the principles and check whether privacy principles are included and specific enough to guide a design decision.
2. Verify designers know them by asking.
3. Review recent architectures against them.
4. Check whether architecture review has ever changed a design on privacy grounds.
5. Verify deviations are documented and approved.

EVIDENCE TO COLLECT

- Documented engineering principles including privacy
- Architecture documentation for recent systems
- Architecture review records with outcomes
- Deviation records with approvals

HOW TO DOCUMENT IT

Assess sampled architectures against each stated principle and record the result per principle, which identifies which are real and which are decorative.

EXECUTIVE SUMMARY TREATMENT

Suggested language: engineering principles address security but not privacy, so minimization and separation of personal data are not designed for and would have to be retrofitted at cost.

A.3.30 Outsourced development

WHAT THE CONTROL ASKS FOR

Direct, monitor, and review outsourced system development. Counterpart: ISO/IEC 27001 Annex A.8.30. The PIMS question includes whether external developers have access to production personal data.

WHY IT EXISTS

Outsourcing transfers the work but not the accountability. External developers frequently receive production data because it is convenient for testing, which is a disclosure to a third party that usually has no basis and no record.

HOW TO AUDIT IT

1. Identify all outsourced development, including work commissioned outside the technology function.
2. Verify contracts specify privacy as well as security requirements.
3. Check whether external developers have access to production personal data, and on what basis.
4. Verify delivered code receives the same review as internal code.
5. Check access was revoked at the end of the engagement.

EVIDENCE TO COLLECT

- Register of outsourced development
- Contracts with privacy and security requirements
- Access records for external developers
- Evidence of data provided to developers

HOW TO DOCUMENT IT

Record whether external developers accessed production personal data, on what basis, and whether that disclosure was recorded. Record access revocation dates against engagement end dates.

EXECUTIVE SUMMARY TREATMENT

Suggested language: external developers were given access to production personal data with no recorded basis and no disclosure record, and a stated number retain that access after their engagements ended.

A.3.31 Test information

WHAT THE CONTROL ASKS FOR

Select, protect, and manage test information appropriately. Counterpart: ISO/IEC 27001 Annex A.8.33. This is the control that most directly determines whether production personal data is being processed in environments never assessed for it.

WHY IT EXISTS

Using production personal data for testing extends its exposure to everyone with test access, in environments with weaker controls, for a purpose that was almost certainly never identified or disclosed. It is simultaneously a security weakness and unlawful processing.

HOW TO AUDIT IT

1. Identify what data is used for testing across all non-production environments.
2. Inspect the actual data rather than the policy, and record the sensitive fields present.
3. Verify any use of production personal data was authorized, has an identified basis, and was disclosed.
4. Check access controls on non-production environments against the personal data they hold.
5. Check retention: how long test data has been present.
6. Verify masking or synthetic data alternatives were considered.

EVIDENCE TO COLLECT

- Non-production environment inventory with data held
- Sample extracts showing actual data present
- Authorization and lawful basis records for production data use
- Access lists for non-production environments
- Masking configuration where applied

HOW TO DOCUMENT IT

Inspect the actual data in a non-production environment and record the sensitive fields found, the record count, and the access population. That population figure is the real exposure and is usually larger than for production.

EXECUTIVE SUMMARY TREATMENT

Suggested language: development and test environments contain the unmasked personal data of a stated number of individuals, accessible to more people than can access production, for a purpose that was never identified, disclosed, or assessed.

Glossary

Terms are listed alphabetically. Each is also indexed at the point of first use.

Annex A

The 78 reference controls attached to ISO/IEC 27701:2025, in three groups: A.1 for PII controllers (31), A.2 for PII processors (18), and A.3 information security controls applying to both (29). As in ISO/IEC 27001, it is a checklist to compare your selected controls against.

Annex B

The implementation guidance introduced in the 2025 edition. Informative rather than normative, but auditors will reasonably expect your implementation to be recognizable against it.

Consent

A freely given, specific, informed, and unambiguous indication of agreement to processing. The most demanding lawful basis and the most frequently defective. Consent that cannot be withdrawn as easily as it was given is not valid consent.

De-identification

Processing that removes the association between data and an individual. Only effective if re-identification is not reasonably possible using other data available to the organization or to a third party, which is a higher bar than simply removing names.

Documented information

The standard's umbrella term for both documents, which state what should happen, and records, which evidence what did happen. In privacy the record frequently is the compliance, since accountability obligations are discharged by demonstration.

Interested party

Any person or organization that can affect, be affected by, or perceive itself to be affected by the organization's activities. For a PIMS this is led by PII principals, who hold enforceable rights regardless of any commercial relationship.

Joint PII controller

A party that determines purposes and means of processing jointly with the organization. Arises more often than recognized, typically through marketing platforms and embedded analytics, and is frequently misclassified as a processor relationship.

Lawful basis

The legal ground permitting processing. Determined per purpose, before processing begins, and demonstrable. The most consequential single determination in the standard and frequently made by people without the competence to make it.

Nonconformity

A failure to meet a requirement, whether from the standard, the organization's own policies, or a legal or contractual obligation.

PII

Personally identifiable information. Any information that can identify a living individual either on its own or combined with other information reasonably available. The equivalent term in European law is personal data, and its scope is broader than most people assume.

PII controller

The party that determines the purposes and means of processing PII. Bears primary accountability. Determined per processing activity, not per organization.

PII principal

The individual the personal data is about. Holds rights exercisable directly against the organization and enforceable by supervisory authorities on their behalf.

PII processor

The party that processes PII on behalf of a controller, under that controller's instructions. Its authority to process comes entirely from those instructions.

PIMS

Privacy Information Management System. The coordinated set of policies, processes, people, and controls through which an organization manages privacy. From the 2025 edition it stands alone and does not require an ISMS underneath it.

Portability

The right to receive personal data in a structured, commonly used, machine-readable format and transmit it to another controller. Generally attaches only to data the individual provided, processed by automated means on a consent or contract basis. Frequently implemented in name only.

Privacy impact assessment

An assessment of processing that may present significant risk to individuals, examining necessity, proportionality, the risks, and the measures addressing them. Looks outward at effects on people, unlike risk assessment, which looks inward at threats to the organization.

Privacy notice

The external document telling individuals what the organization does with their data. Distinct from the internal privacy policy, which tells staff what they must do. Conflating the two is among the most common failures in Clause 5.2.

Processing

Any operation performed on PII, including collection, storage, use, disclosure, and erasure. Storing data without doing anything else with it is still processing.

Records of processing

The inventory of processing activities covering purposes, categories, recipients, transfers, retention, and security measures. The foundational accountability document and the first thing a supervisory authority requests.

Residual risk

The risk remaining after controls are applied and working as intended. Must be accepted by the risk owner, not by the privacy function on their behalf.

Special category data

Personal data whose processing carries a higher threshold, typically covering health, biometrics, ethnicity,

religion, sexual orientation, and similar. Terminology varies by jurisdiction; the higher threshold does not.

Statement of Applicability

The document listing all 78 Annex A controls with an applicability decision and justification for each. Usually shortened to SoA. Applicability of A.1 and A.2 depends on the organization's role, which is determined per processing activity.

Sub-processor

A party engaged by a processor to carry out part of the processing. Requires customer authorization and must be bound by obligations matching those the processor owes its customer.

Supervisory authority

The regulator responsible for enforcing privacy law in a given jurisdiction. Which one applies follows from where the individuals are, not from where the organization is.

Transfer

Movement of PII between jurisdictions. Includes remote access from another jurisdiction, which is a transfer that appears on no data flow diagram and is the most commonly unidentified example.

Workpaper

The auditor's record of what was tested, how, what was found, and what was concluded. Written so a reviewer can follow the reasoning without re-performing the work.

Index of Terms and Concepts

- Access rights, 91
- Access, correction or erasure, 45
- Accuracy and quality, 52
- Actions to address risks and opportunities:
 - general, 10
- Addressing information security within supplier agreements, 92
- Annex A, 114
- Annex B, 114
- Application security requirements, 110
- Automated decision making, 49
- Awareness, 17
- Basis for PII transfer between jurisdictions, 75
- Change of subcontractor to process PII, 82
- Classification of information, 87
- Clear desk and clear screen, 101
- Communication, 18
- Competence, 16
- Compliance with policies, rules and standards for information security, 98
- Comply with obligations to PII principals, 71
- Confidentiality or non-disclosure agreements, 100
- Consent, 114
- Continual improvement, 28
- Contracts with PII processors, 37
- Control of documented information, 21
- Countries and international organizations to which PII can be transferred, 60, 76
- Creating and updating documented information, 20
- Customer agreement, 65
- Customer obligations, 69
- De-identification, 114
- Determine when and how consent is to be obtained, 34
- Determining and fulfilling obligations to PII principals, 40
- Determining information for PII principals, 41
- Determining the scope of the PIMS, 5
- Disclosure of subcontractors used to process PII, 80
- Disposal, 57
- Documented information, 19, 114
- Documented information: general, 19
- Engagement of a subcontractor to process PII, 81
- Handling requests, 48
- Identify and document purpose, 32
- Identify basis for PII transfer between jurisdictions, 59
- Identify lawful basis, 33
- Identity management, 90
- Independent review of information security, 97
- Information backup, 106
- Information security awareness, education and training, 99
- Information security incident management planning and preparation, 93
- Information security roles and responsibilities, 86
- Information transfer, 89
- Infringing instruction, 68
- Interested party, 114
- Internal audit, 26
- Joint PII controller, 38, 114
- Labelling of information, 88
- Lawful basis, 114
- Leadership and commitment, 7
- Legal, statutory, regulatory and contractual requirements, 95
- Legally binding PII disclosures, 79
- Limit collection, 50
- Limit processing, 51
- Logging, 107
- Management review, 27
- Marketing and advertising use, 67

Monitoring, measurement, analysis and evaluation, 25

Nonconformity, 114
nonconformity, 29

Nonconformity and corrective action, 29

Notification of PII disclosure requests, 78

Obtain and record consent, 35

Operational planning and control, 22

Organization's purposes, 66

Outsourced development, 112

PII, 115

PII controller, 115

PII controllers' obligations to inform third parties, 46

PII de-identification and deletion at the end of processing, 54

PII minimization objectives, 53

PII principal, 115

PII principals, 4

PII processor, 115

PII transmission controls, 58, 74

PIMS, 3, 115

Planning of changes, 14

Policies for information security, 85

Policy, 8

Portability, 115

Privacy impact assessment, 36, 115

Privacy information management system, 6

Privacy notice, 115

Privacy objectives and planning to achieve them, 13

Privacy risk assessment, 11, 23

Privacy risk treatment, 12, 24

Processing, 115

Protection of records, 96

Providing copy of PII processed, 47

Providing information to PII principals, 42

Providing mechanism to modify or withdraw consent, 43

Providing mechanism to object to PII processing, 44

Records of PII disclosures to third parties, 62, 77

Records of processing, 115

Records of transfer of PII, 61

Records related to processing PII, 39, 70

Residual risk, 115

Resources, 15

Response to information security incidents, 94

Retention, 56

Return, transfer or disposal of PII, 73

Roles, responsibilities and authorities, 9

Secure authentication, 105

Secure development life cycle, 109

Secure disposal or re-use of equipment, 103

Secure system architecture and engineering principles, 111

Special category data, 115

Statement of Applicability, 12, 116

Storage media, 102

Sub-processor, 116

Supervisory authority, 116

Temporary files, 55, 72

Test information, 113

Transfer, 116

Understanding the needs and expectations of interested parties, 4

Understanding the organization and its context, 3

Use of cryptography, 108

User endpoint devices, 104

Workpaper, 116